

Vulnerability Scanning & Risk Triage with Nessus

A step-by-step build log: install, scan, troubleshoot, triage, and remediate — on an isolated VirtualBox lab (Kali Linux, Windows Server 2022, Windows 11).

Prepared by: Anush

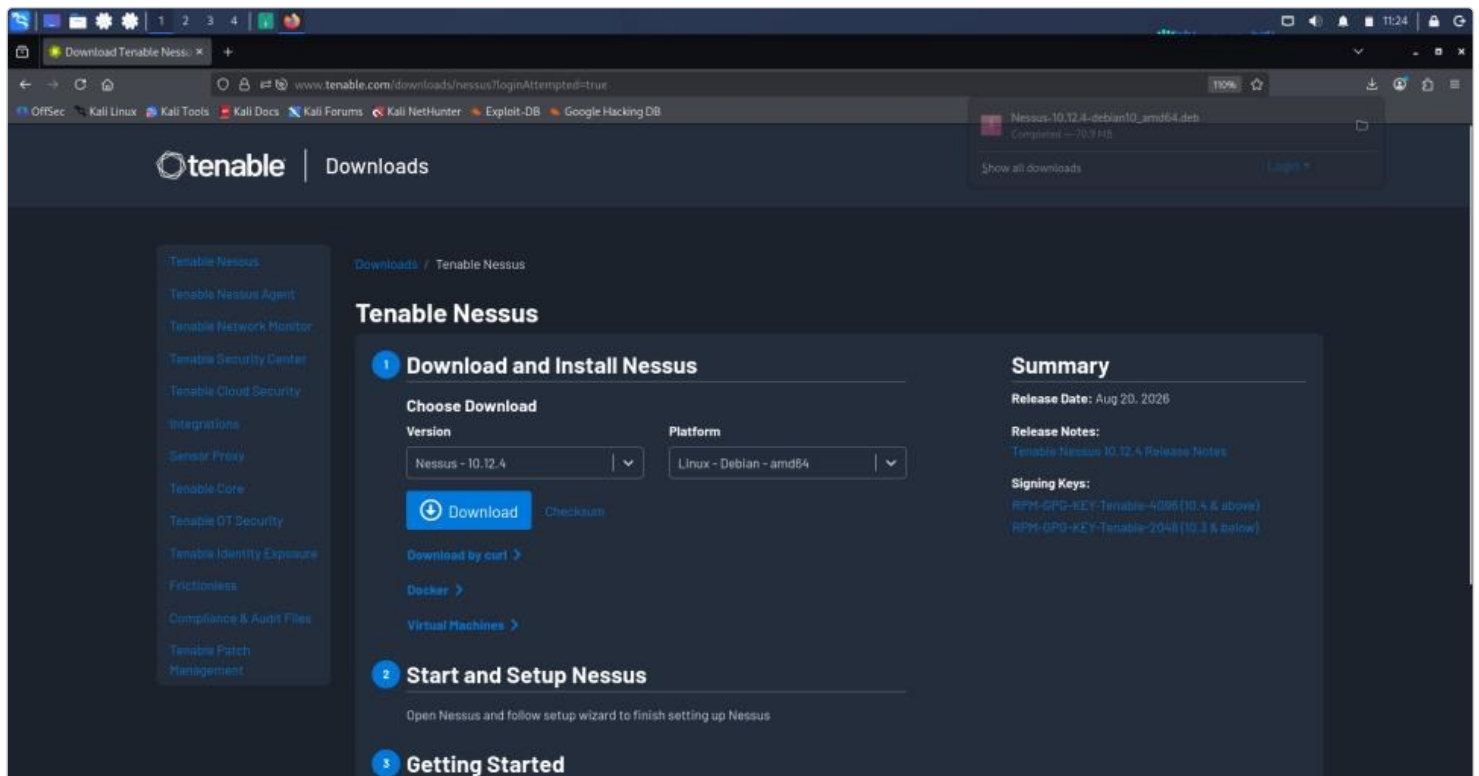
Type: Personal home lab project (not professional/client work)

Status: Studying toward CompTIA Security+

Phase 1 · Installing & Configuring Nessus

Setting up Nessus Essentials on the Kali Linux VM — including a real disk-space problem that came up mid-install.

- 1 Downloading Nessus on the Kali machine, straight from the official Tenable website.



- 2 Nessus installed successfully — core components and signature checks all pass.

```
kali@kali: ~/Downloads

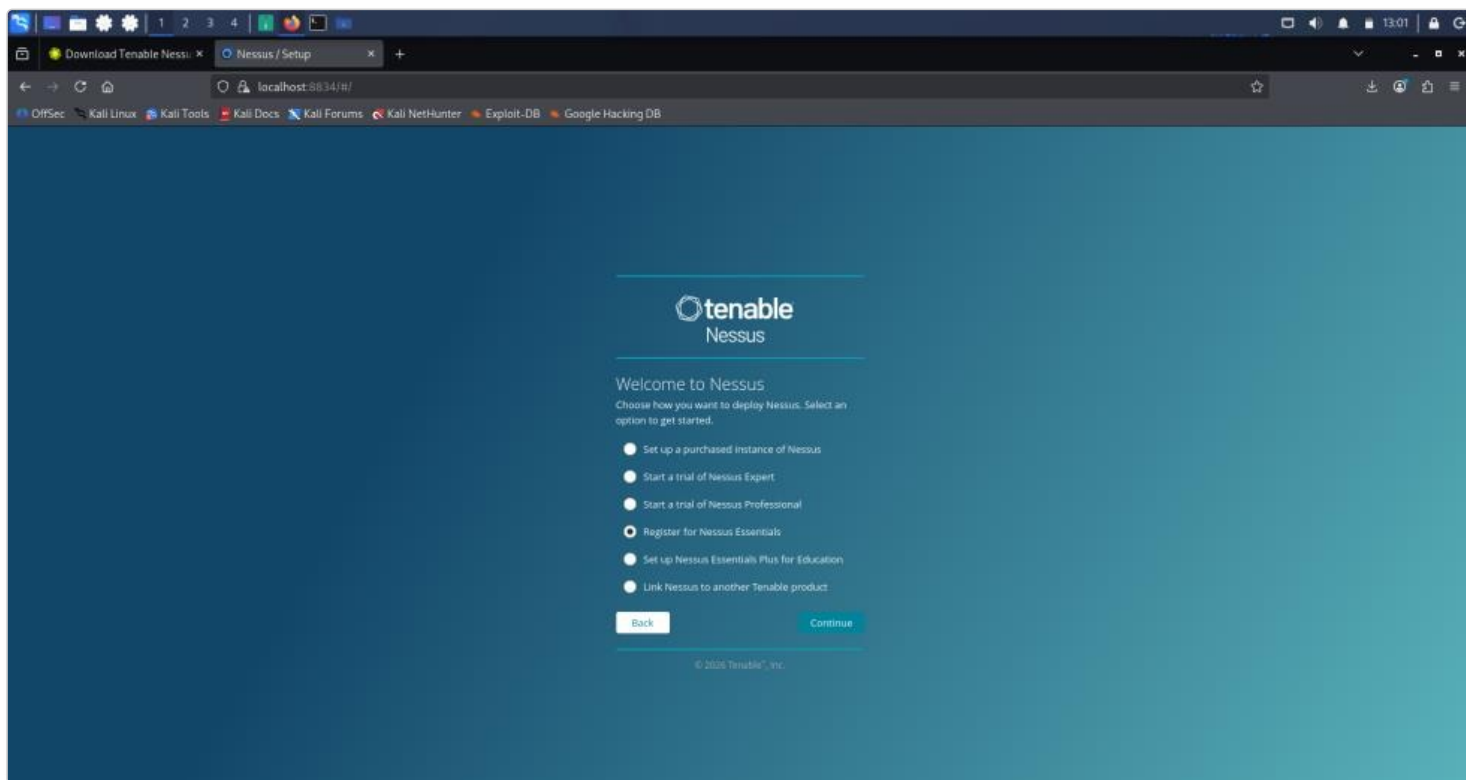
Session Actions Edit View Help

DSA : (KAT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KBKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
  name:      OpenSSL FIPS Provider
  version:   3.1.2
  build:     3.1.2
INSTALL PASSED
Unpacking Nessus Scanner Core Components ...

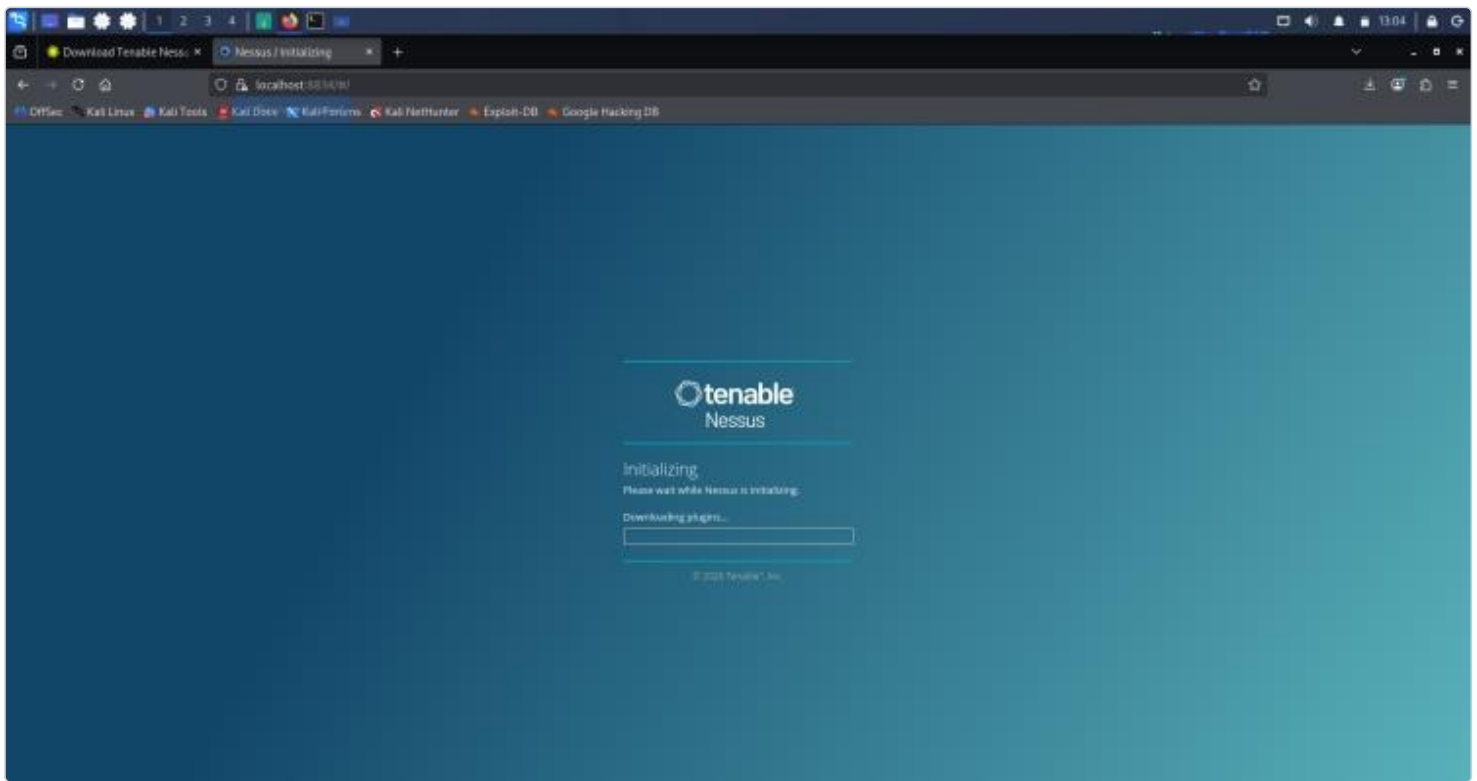
- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://NESSUS_HOSTNAME_OR_IP:8834/ to configure your scanner

(kali@kali)-[~/Downloads]
$
```

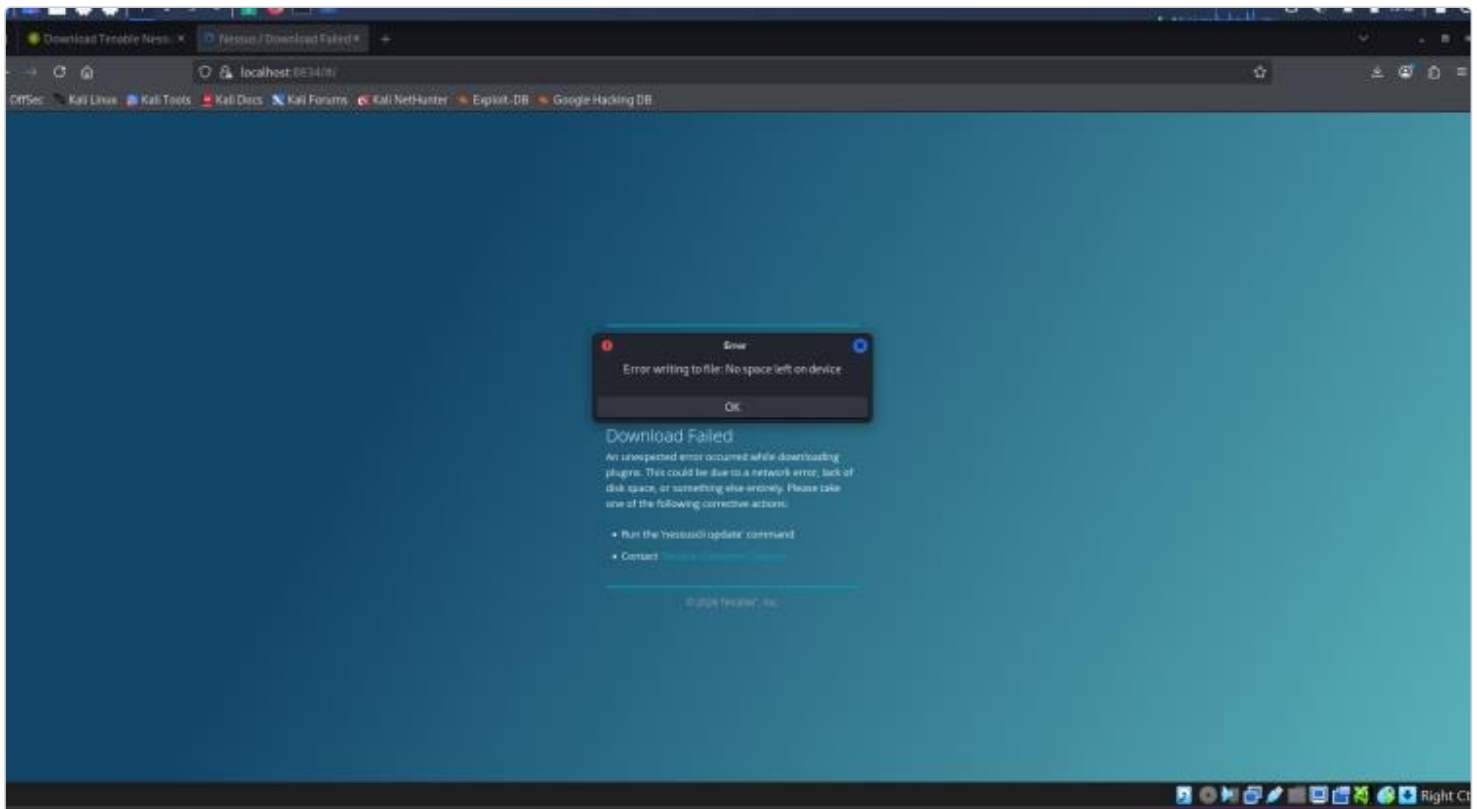
- 3 Opening the browser and selecting Nessus Essentials (the free tier) to begin setup.



- 4 Entered the activation code (emailed by Tenable after registering) — Nessus starts downloading its vulnerability plugins.



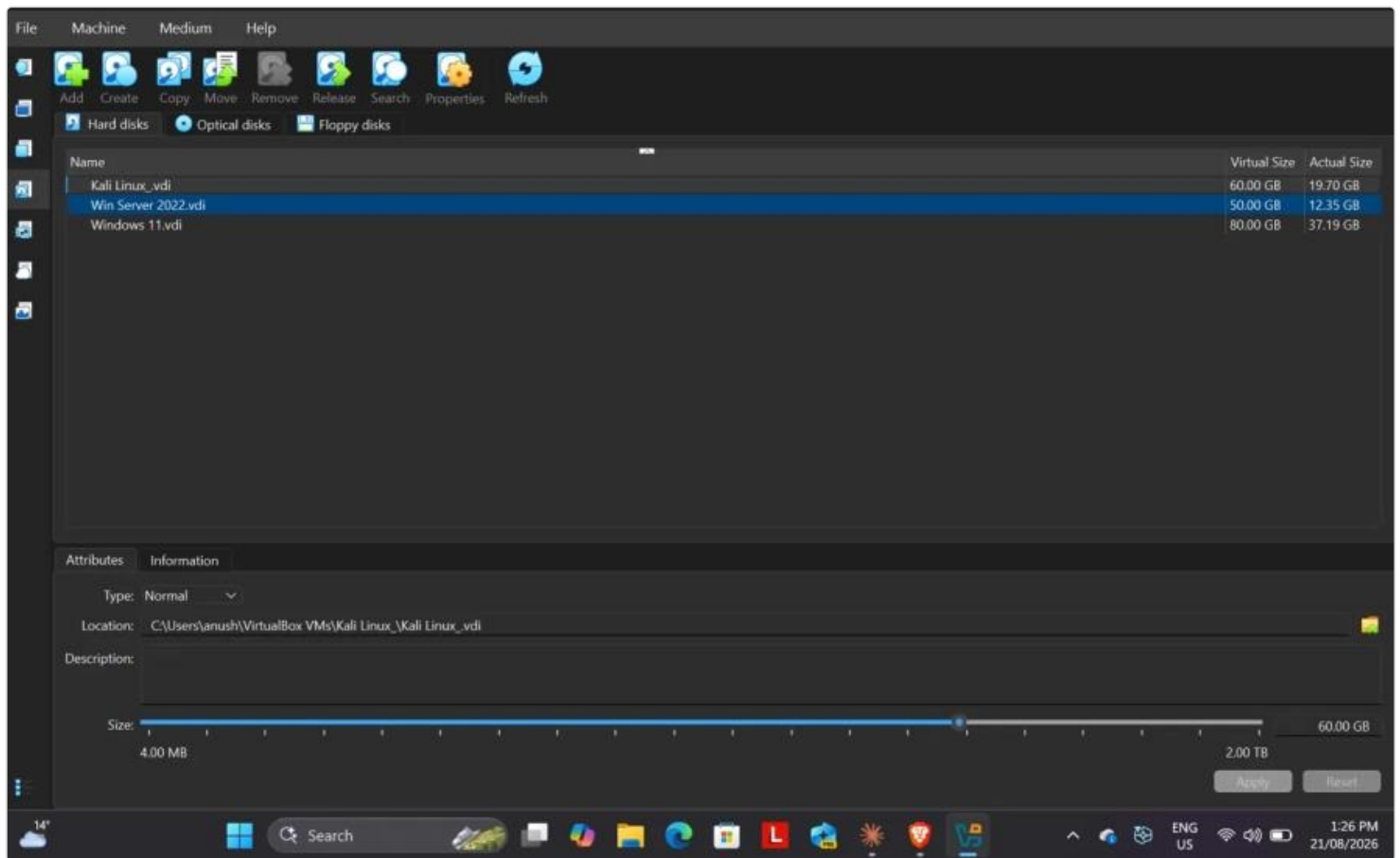
- 5 Ran into a real error partway through the plugin download. Running `df -h` in the terminal showed the Kali VM only had 20 GB of disk assigned, and it had completely run out of space.



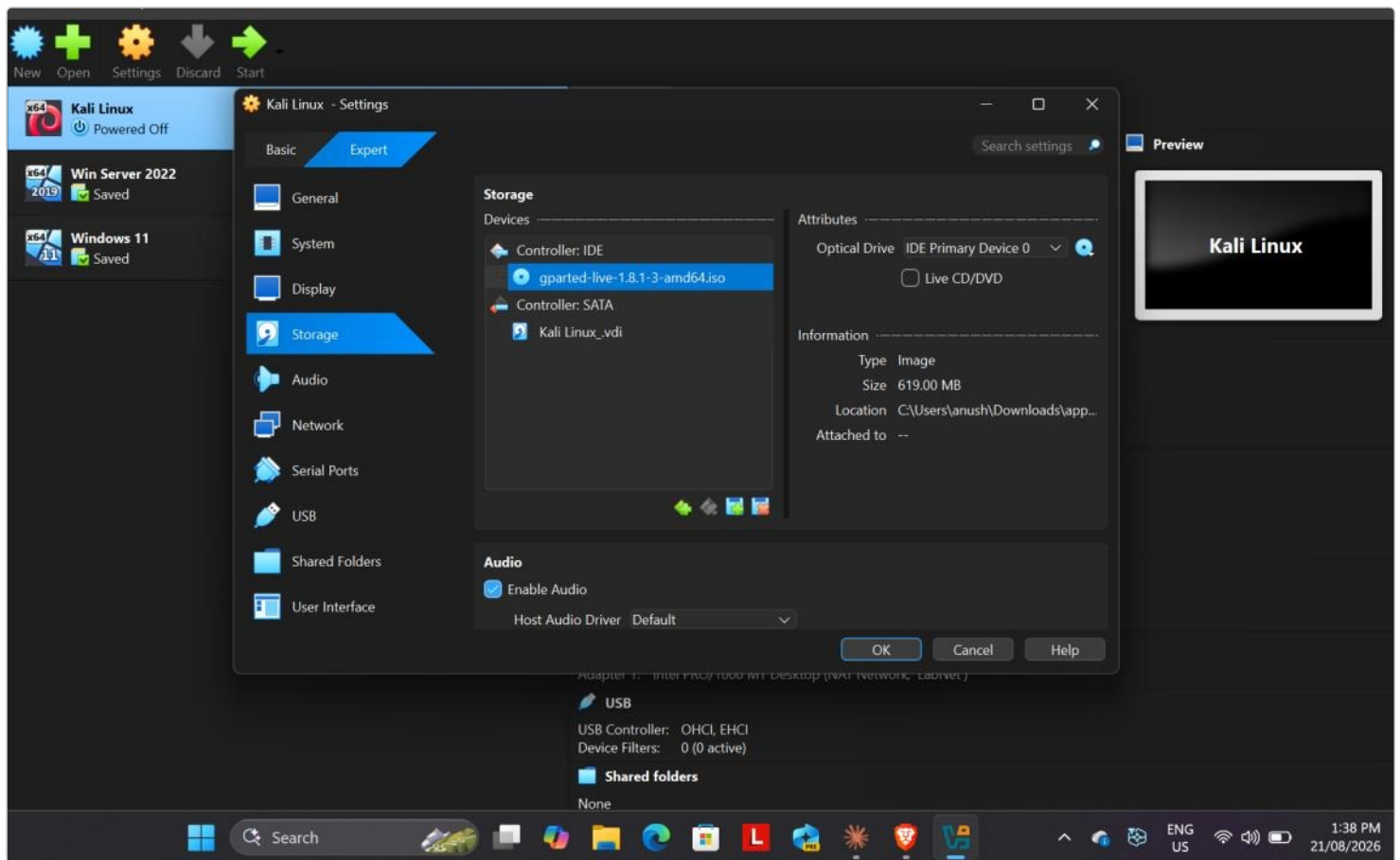
✦ What is `df -h`?

`df -h` is a Linux command that shows disk space usage in human-readable form (GB/MB instead of raw bytes). It's usually the first thing to check when something fails to install or download for no obvious reason.

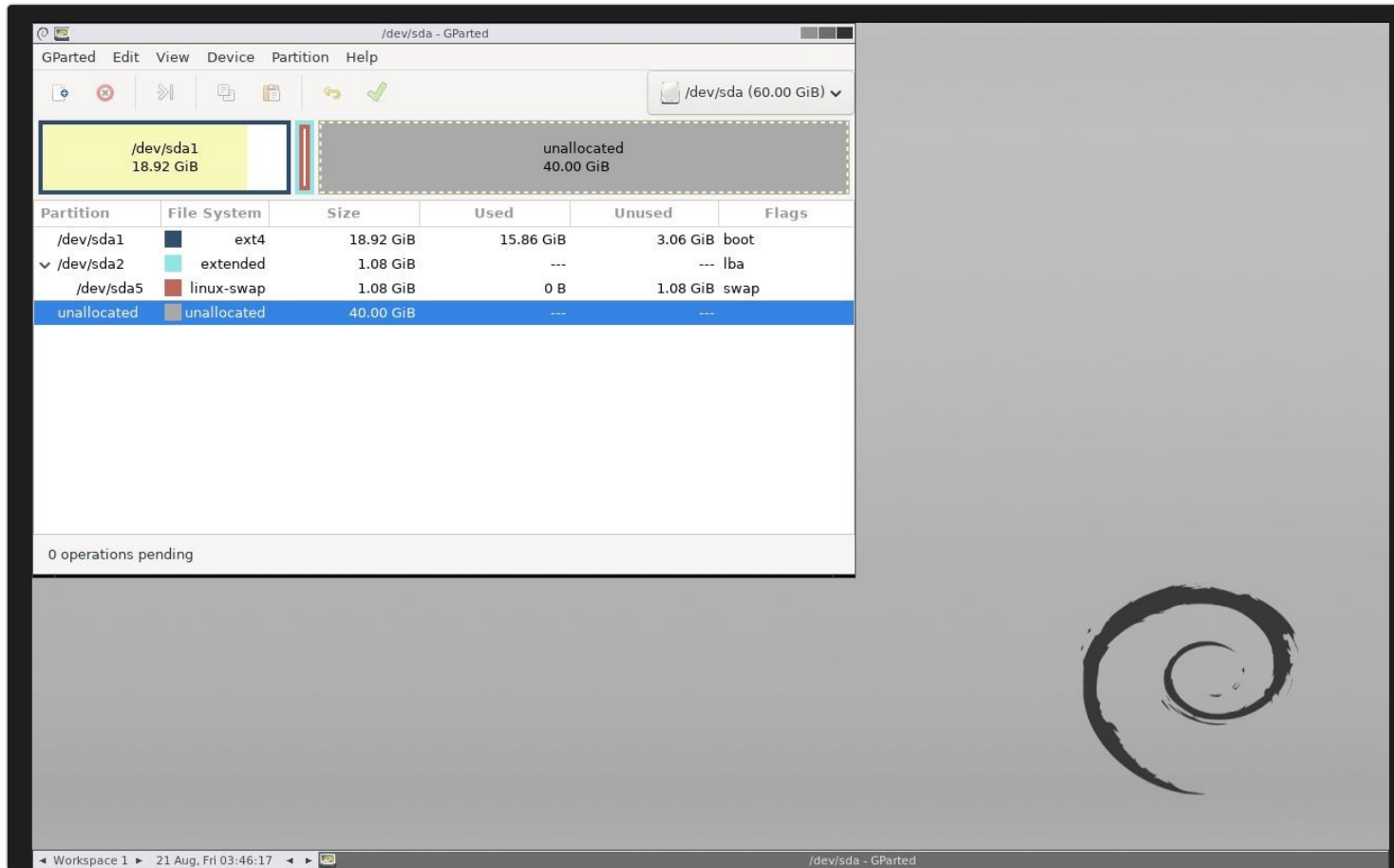
- 6 Fix: powered off the VM, attached a GParted Live ISO to the optical drive, and resized the virtual disk before touching any partitions.



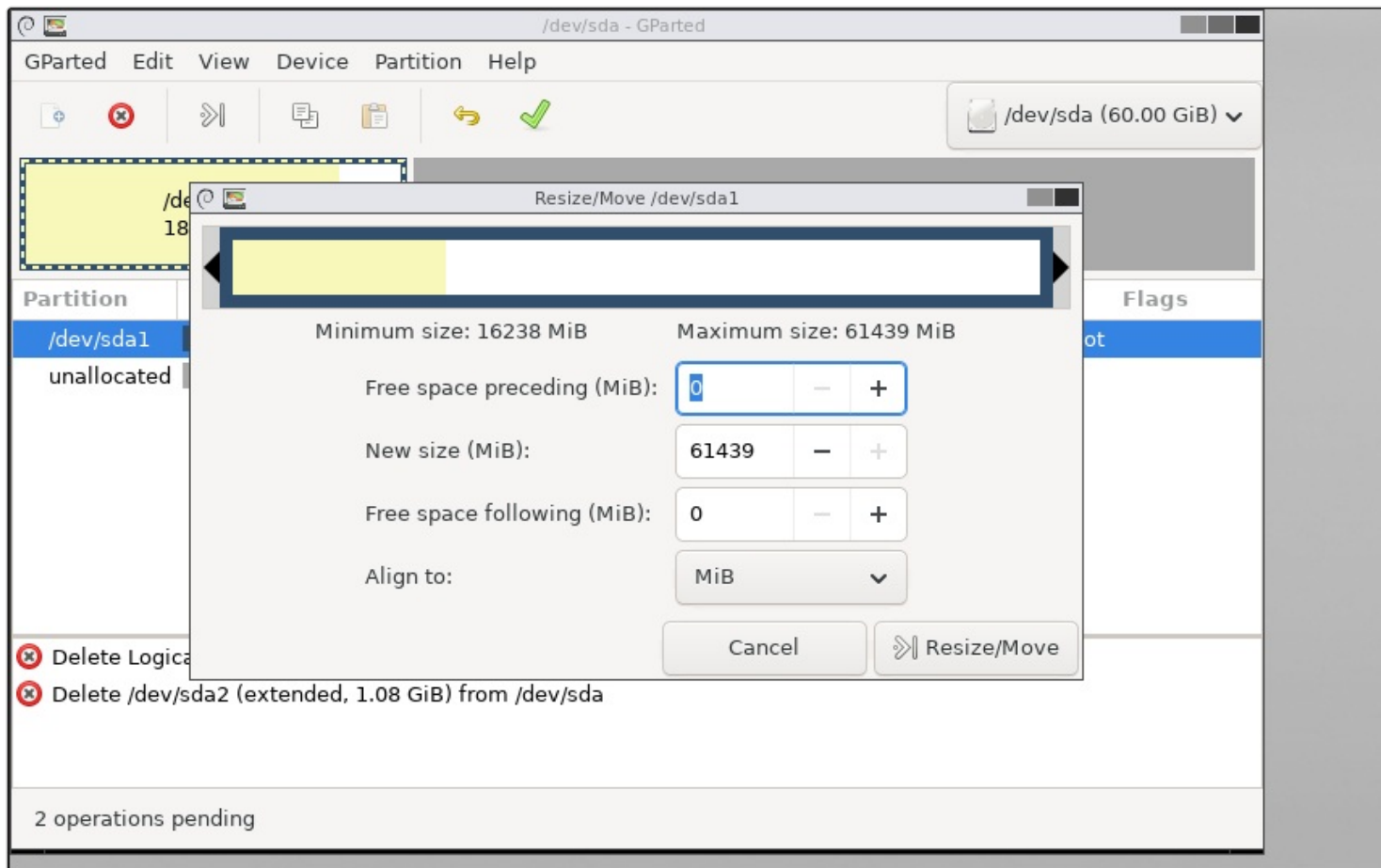
- 7 GParted showing the Kali VM disk after growing the virtual disk to 60GB — the original ~19GB root partition (/dev/sda1) plus a small swap partition, with ~40GB unallocated and not yet usable.



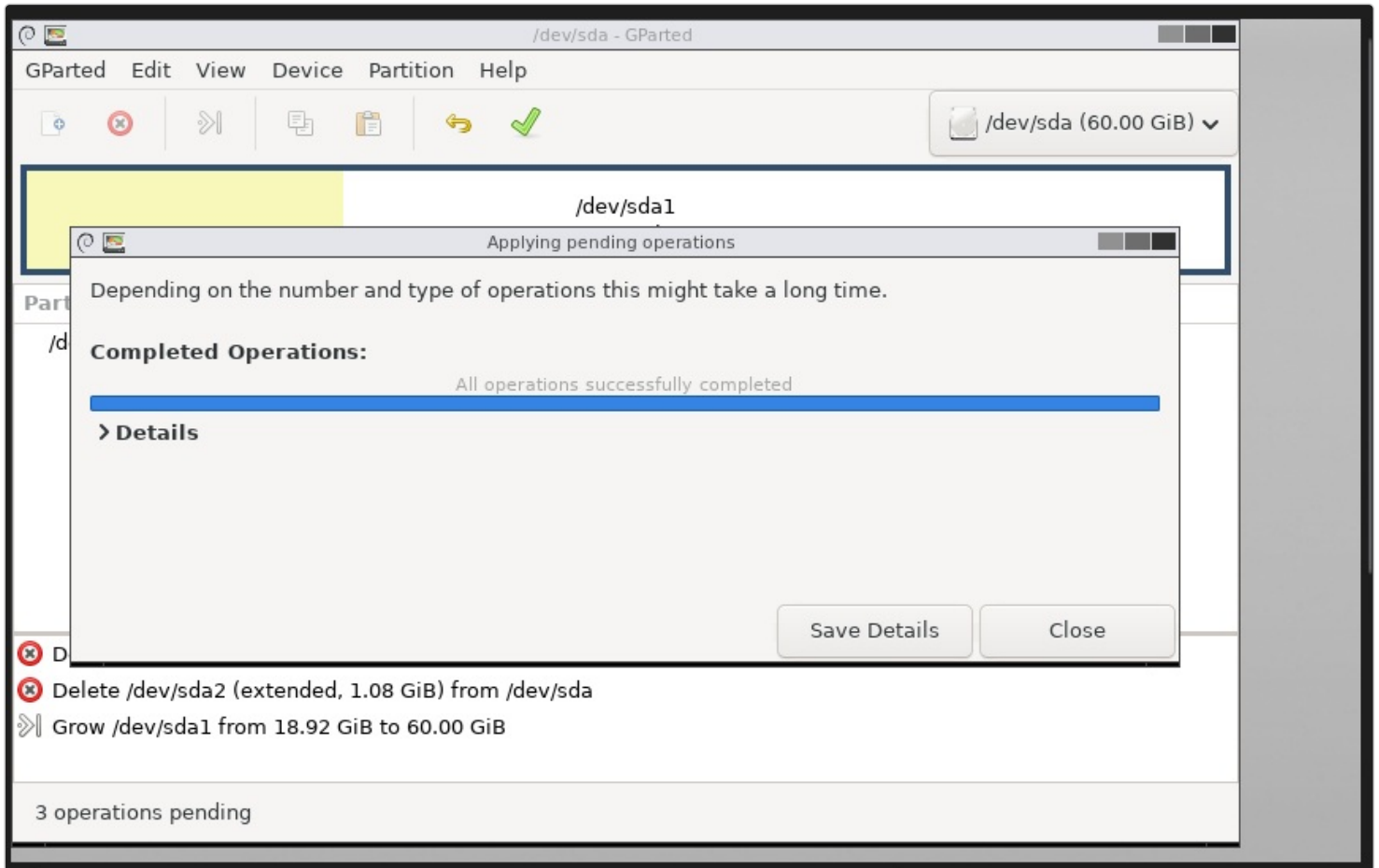
8 Resizing /dev/sda1 to use the full 60GB disk, after first removing the old swap partition that was blocking the free space from being used.



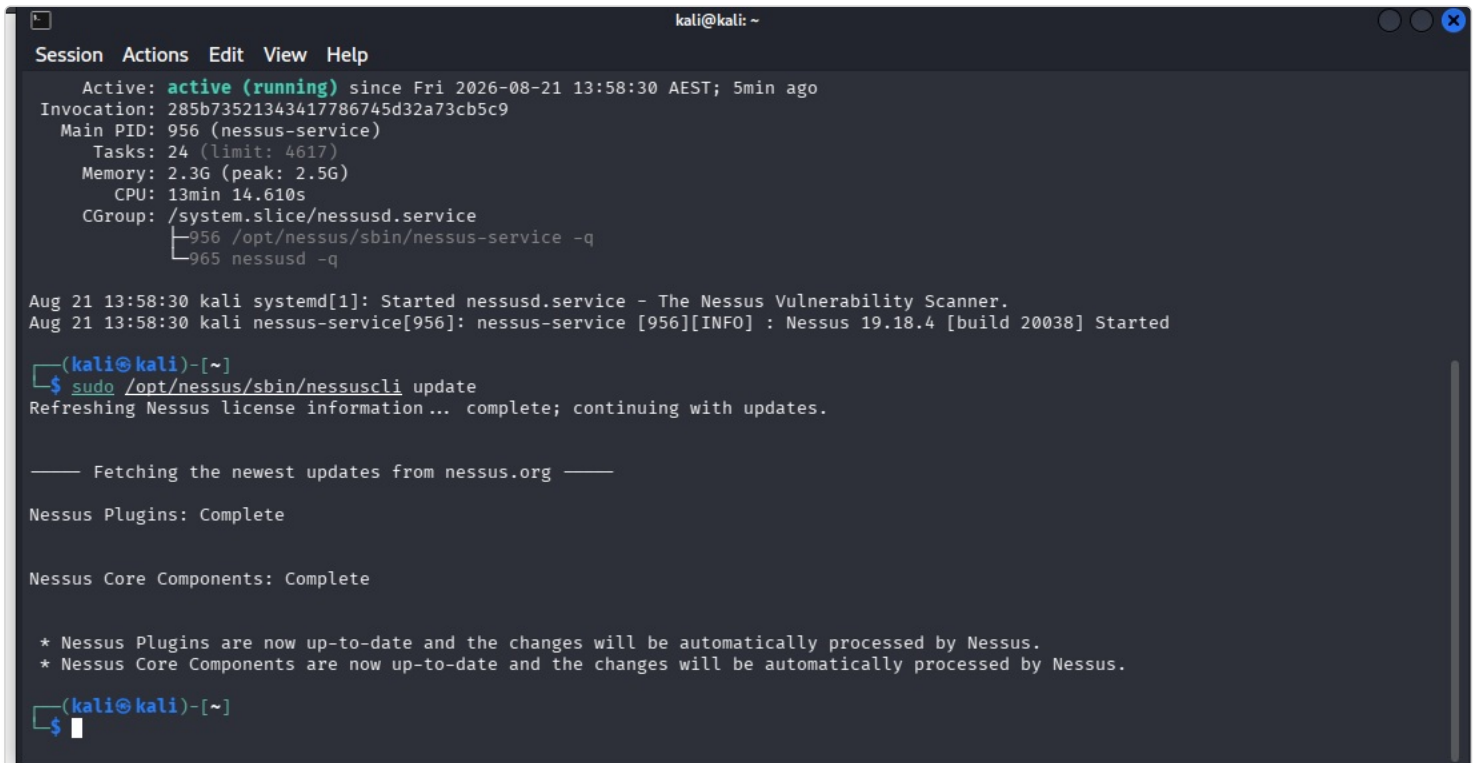
9 GParted confirms all operations completed — root partition grown from 18.92GB to 60GB.



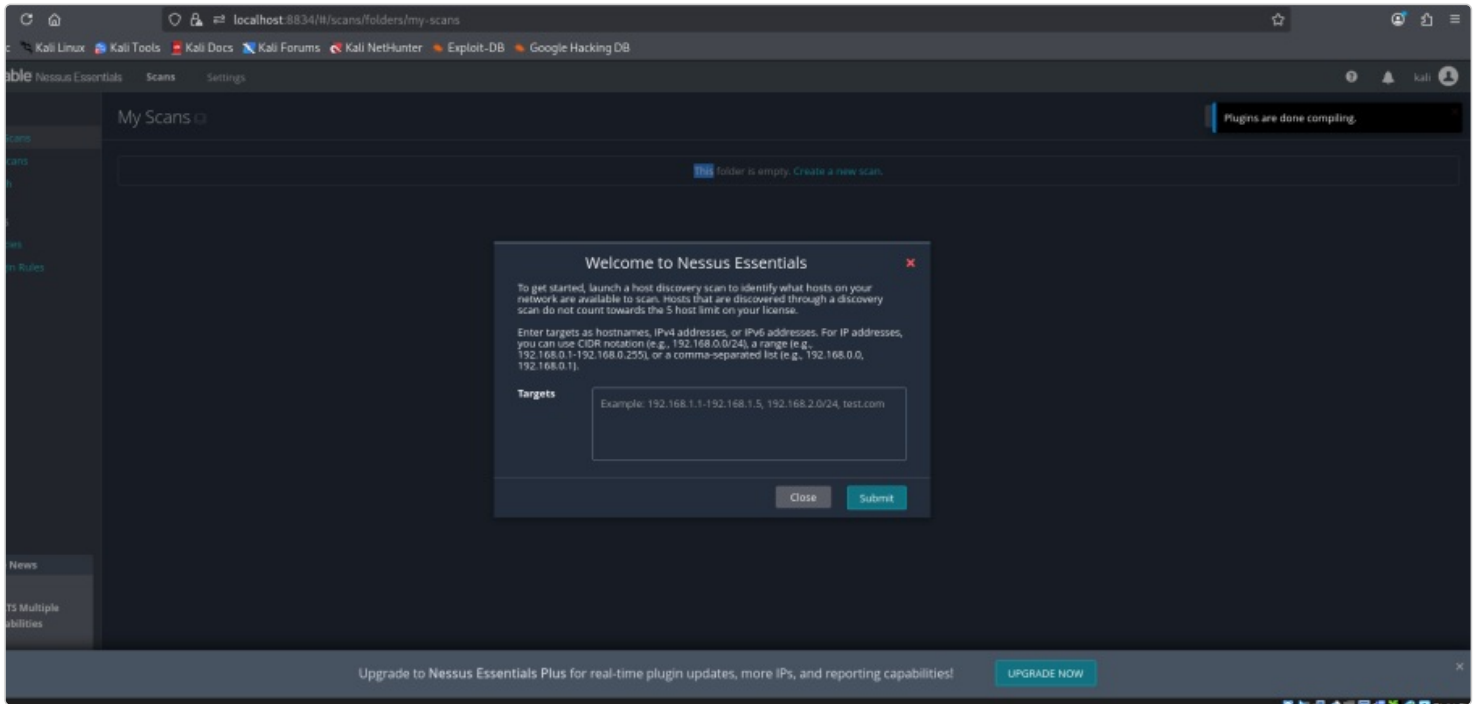
- 10 Resize operation finished with no errors.



- 11 Reinstalled/resumed Nessus after fixing the disk space — confirmed working via the 'Plugins are done compiling' message in the terminal.



12 Nessus Essentials web interface now fully up and ready, with scan-creation options working.



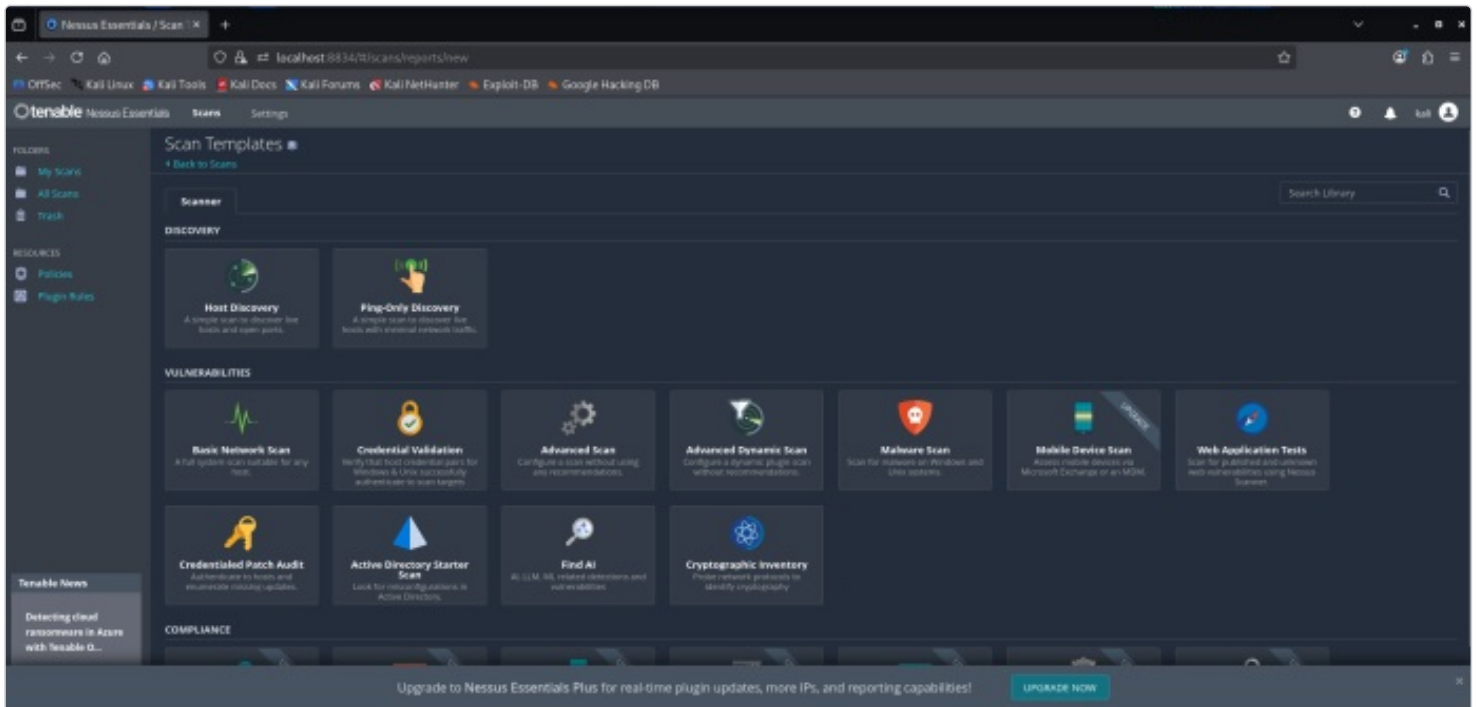
Phase 2 · Unauthenticated Baseline Scan

Before logging into anything, ran a baseline scan to see what an outside attacker with zero access could actually see.

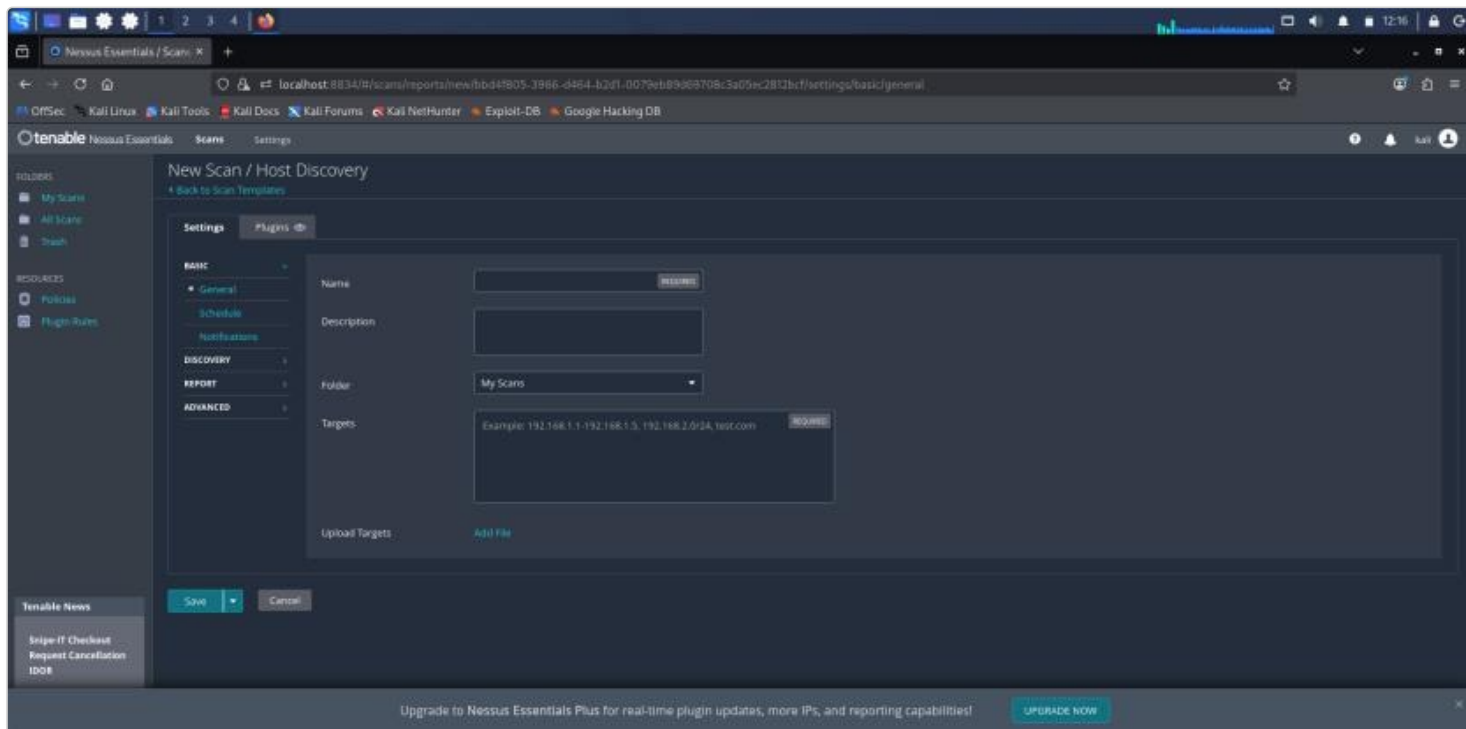
✦ Unauthenticated vs. credentialed scanning

An **unauthenticated** scan checks a target the way an outside attacker would — no login, just what's exposed over the network. A **credentialed** scan logs in with real credentials and checks what's installed and configured underneath. Credentialed scans nearly always find far more, because most vulnerabilities (like missing patches) simply aren't visible from outside.

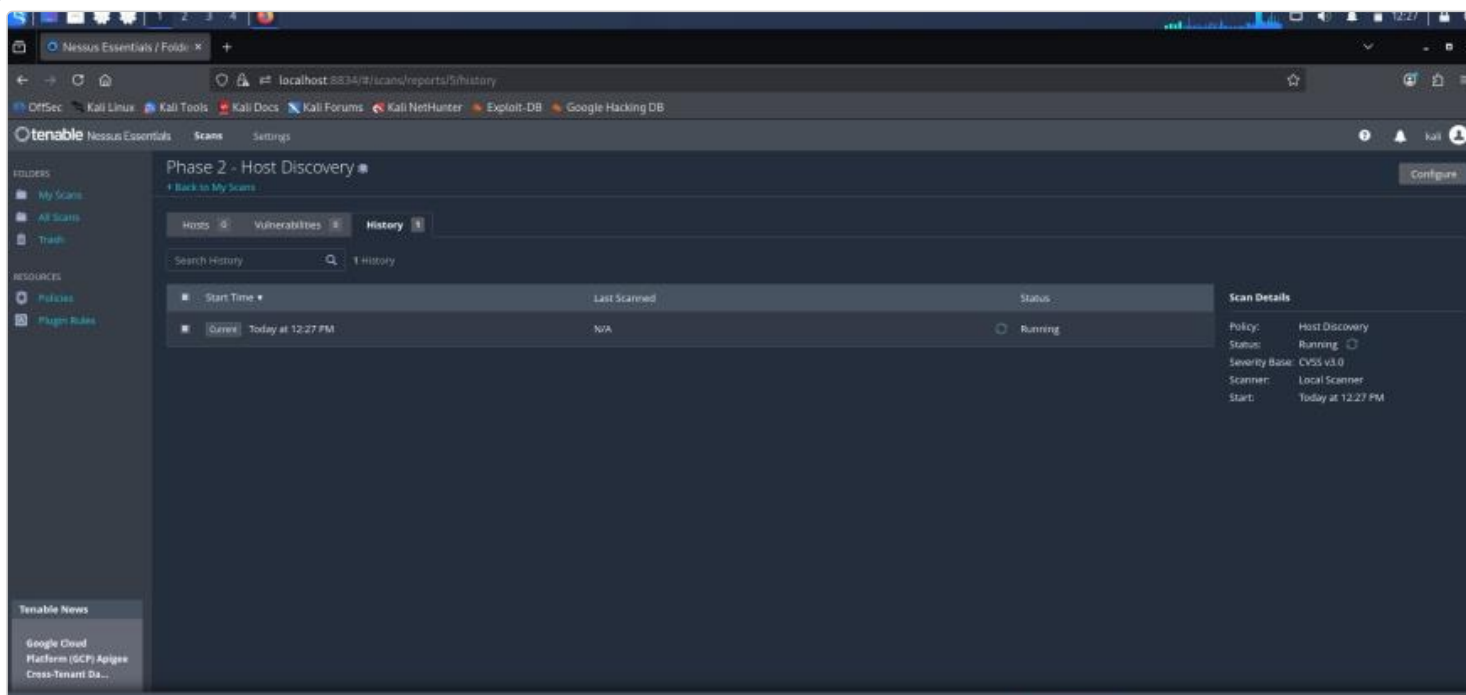
13 Nessus scan template library — selecting the scan type to run against the lab.



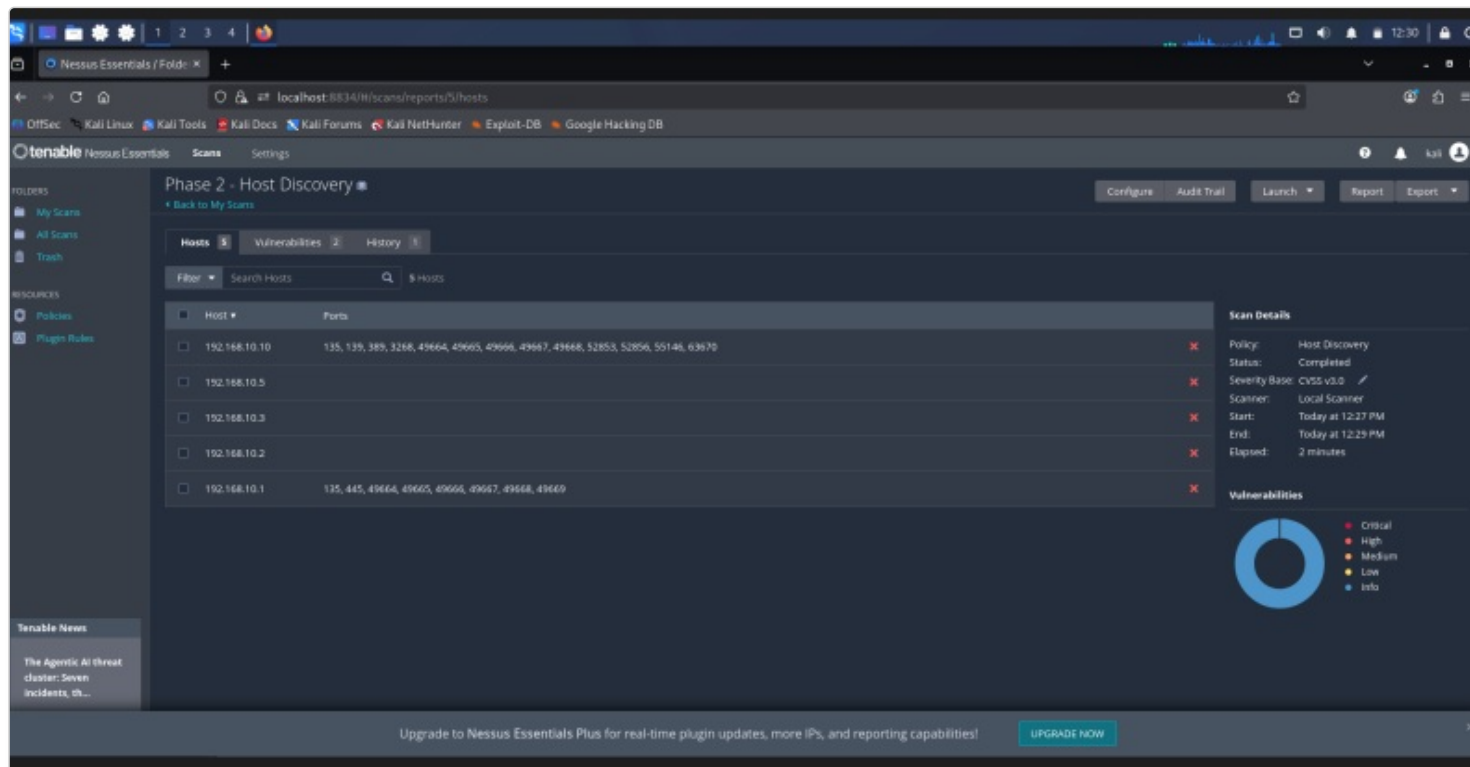
- 14 Configured a Host Discovery scan targeting the full LabNet subnet (192.168.10.0/24), to confirm Nessus can see all three lab VMs before running deeper scans.



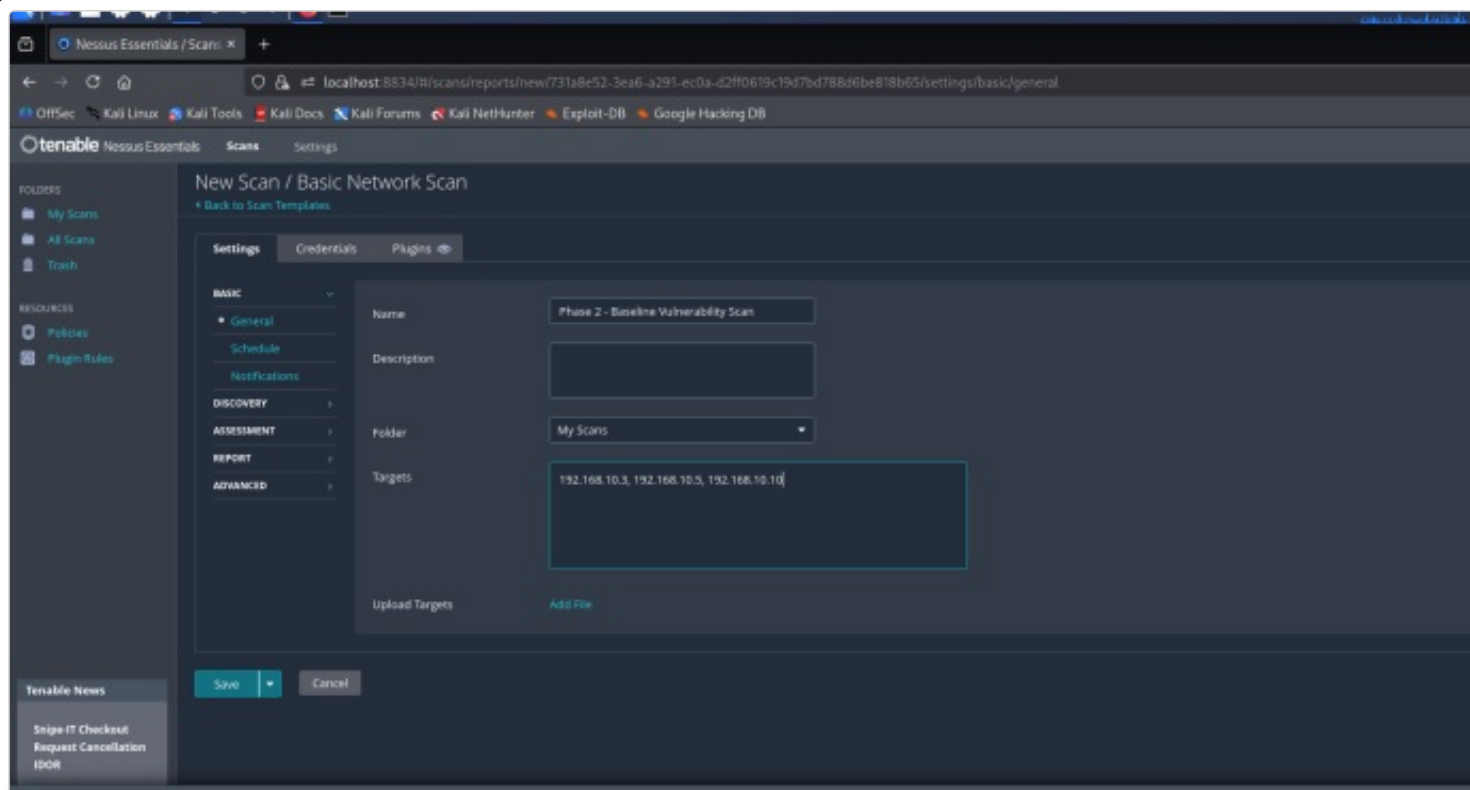
- 15 First Nessus scan launched — Host Discovery running against the LabNet subnet.



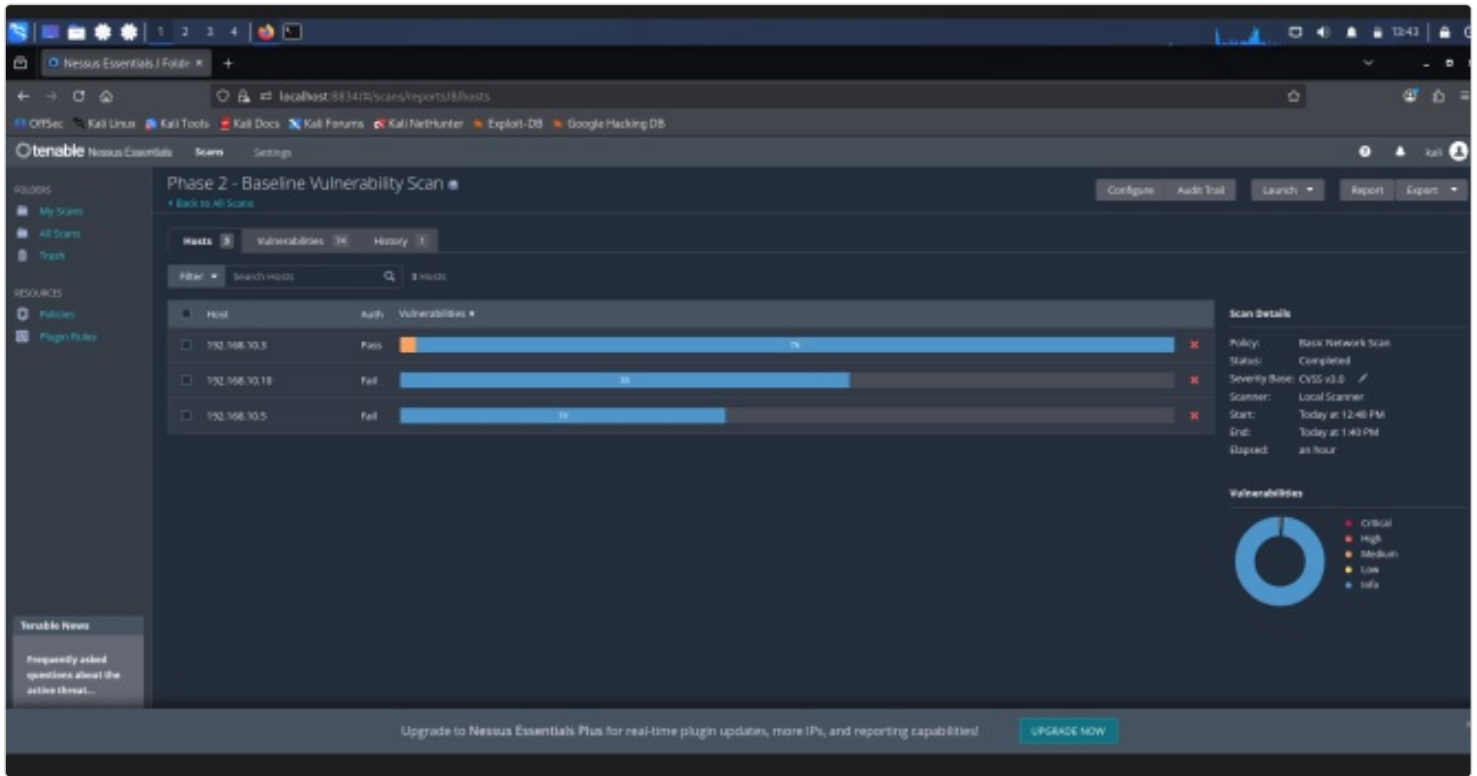
16 Host Discovery completed — identified 5 live hosts on the subnet in 2 minutes.



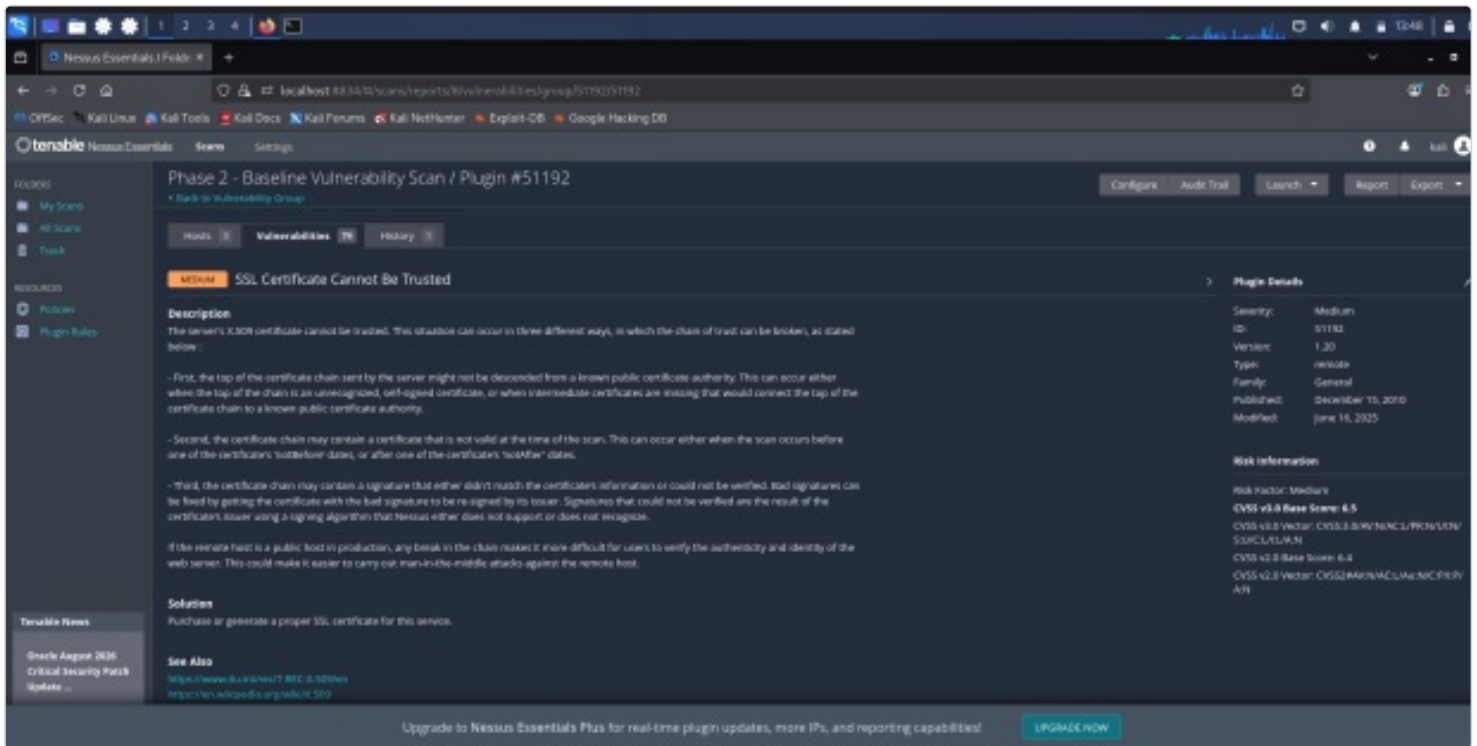
17 Configured a Basic Network Scan targeting the three actual lab VMs directly (Kali, Windows Server 2022, Windows 11), instead of scanning the whole subnet blindly.



18 Baseline vulnerability scan completed against all three lab VMs — 74 findings total, nearly all informational.



19 The one non-informational finding from this baseline scan: a self-signed SSL certificate on Nessus's own management interface (port 8834). Assessed as an accepted risk rather than a real defect, since it's a local admin-only interface, not a production or public-facing service.



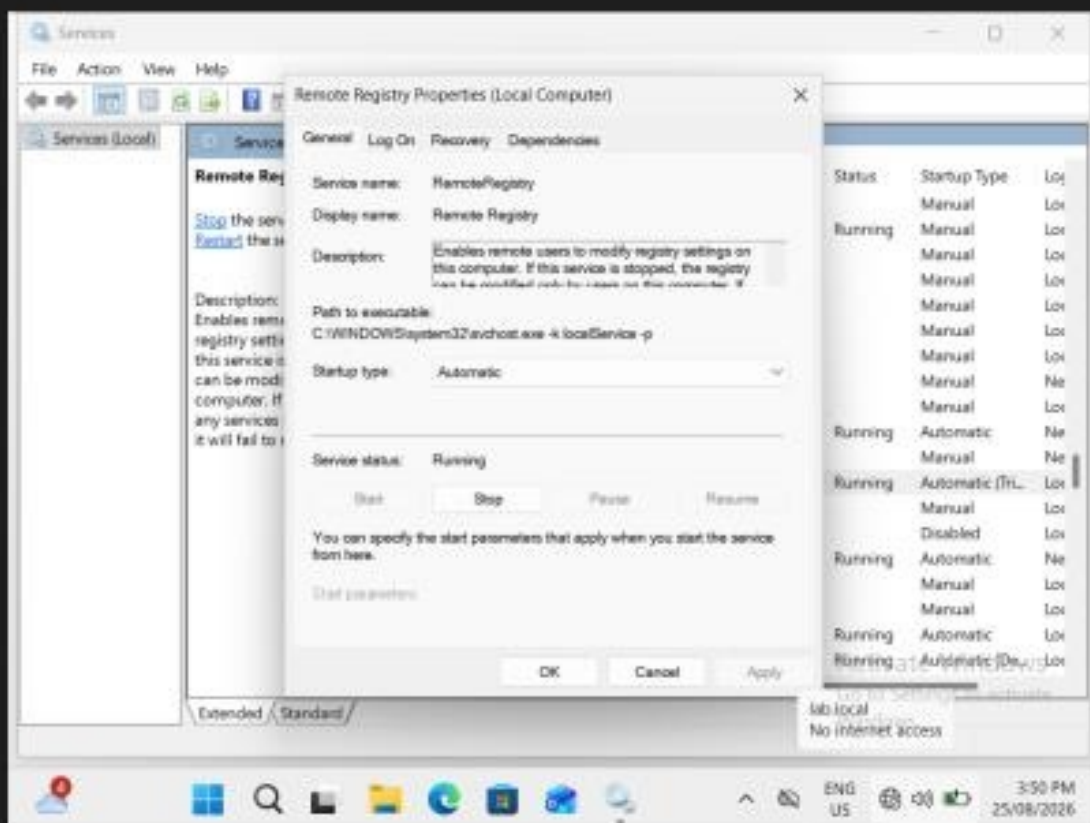
Phase 3 · Credentialed Scan & Troubleshooting

This was the phase with the most real troubleshooting: firewall rules, service dependencies, and Nessus authentication quirks. Every fix below was a genuine problem, not a guess.

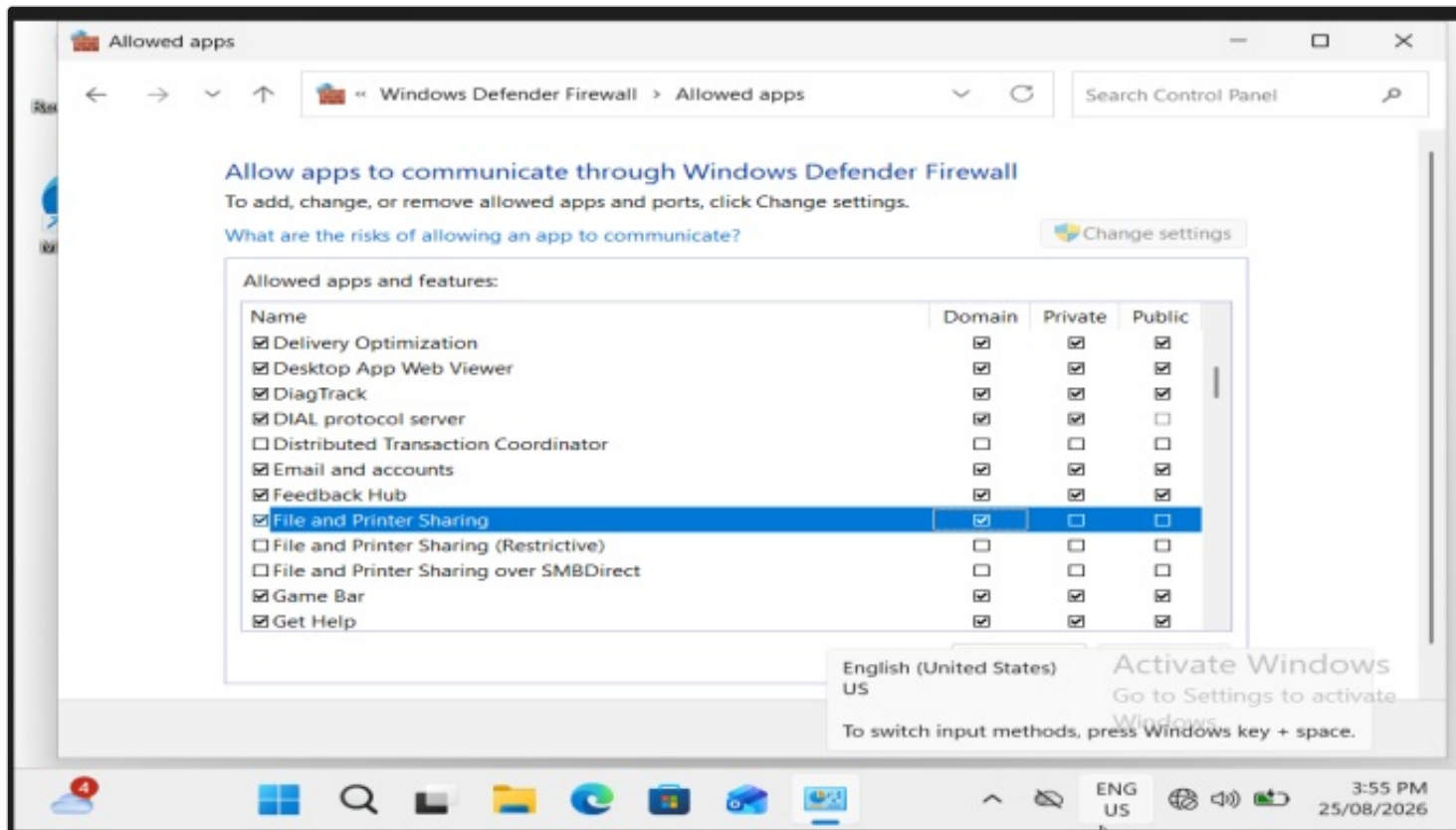
★ Why Windows needs extra setup for credentialed scans

Nessus authenticates to Windows over the network using Windows' own remote-management protocols (WMI and Remote Registry). Those are **off by default** on a fresh Windows installation for security reasons — so before a credentialed scan can even attempt to log in, three things generally need to be true on the target: Remote Registry service running, the WMI firewall rule allowed, and the File and Printer Sharing firewall rule allowed (all on the Domain network profile).

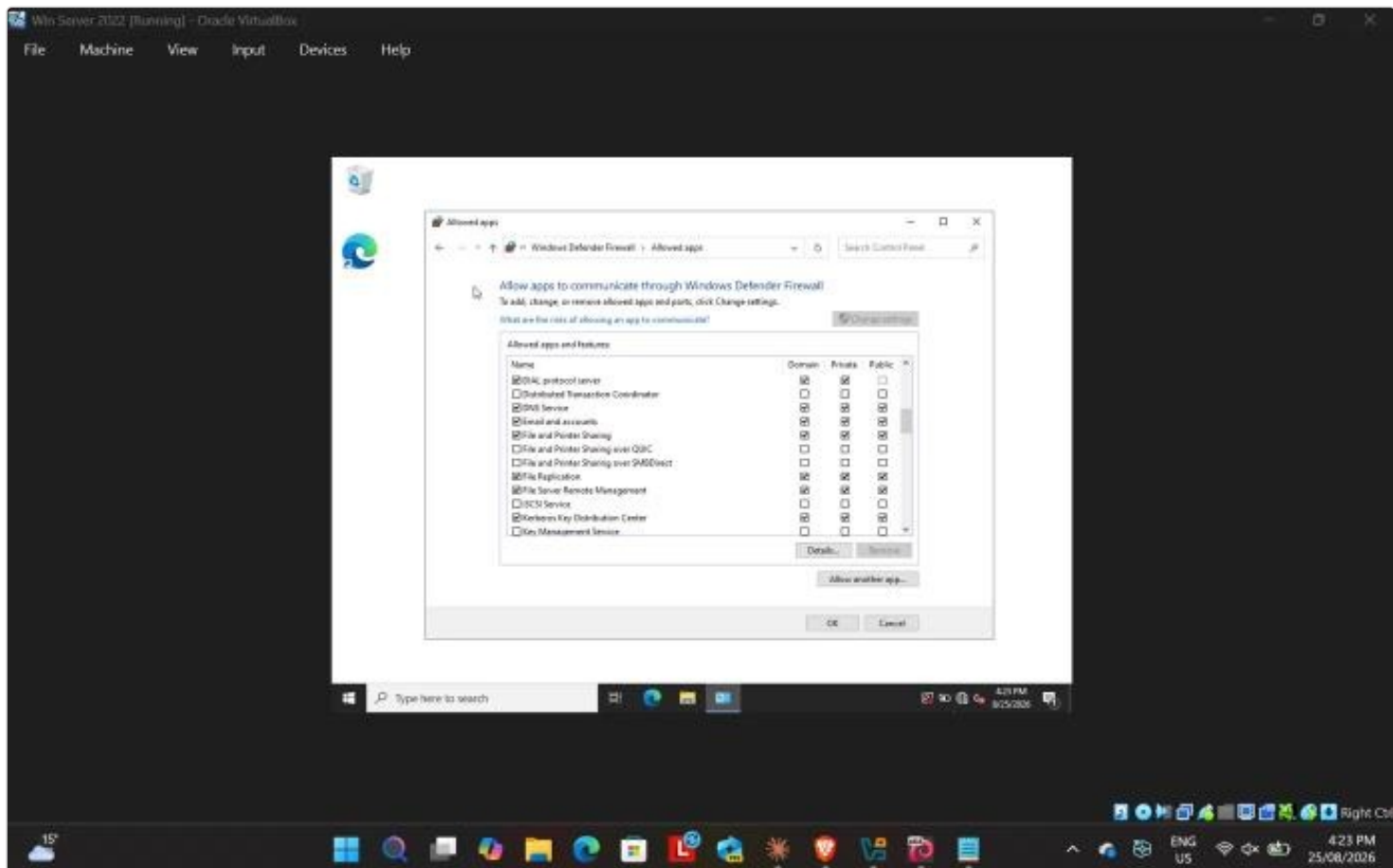
20 Enabled and started the Remote Registry service on Windows 11 (via the elevated Services console) — required for Nessus to run a credentialed scan.



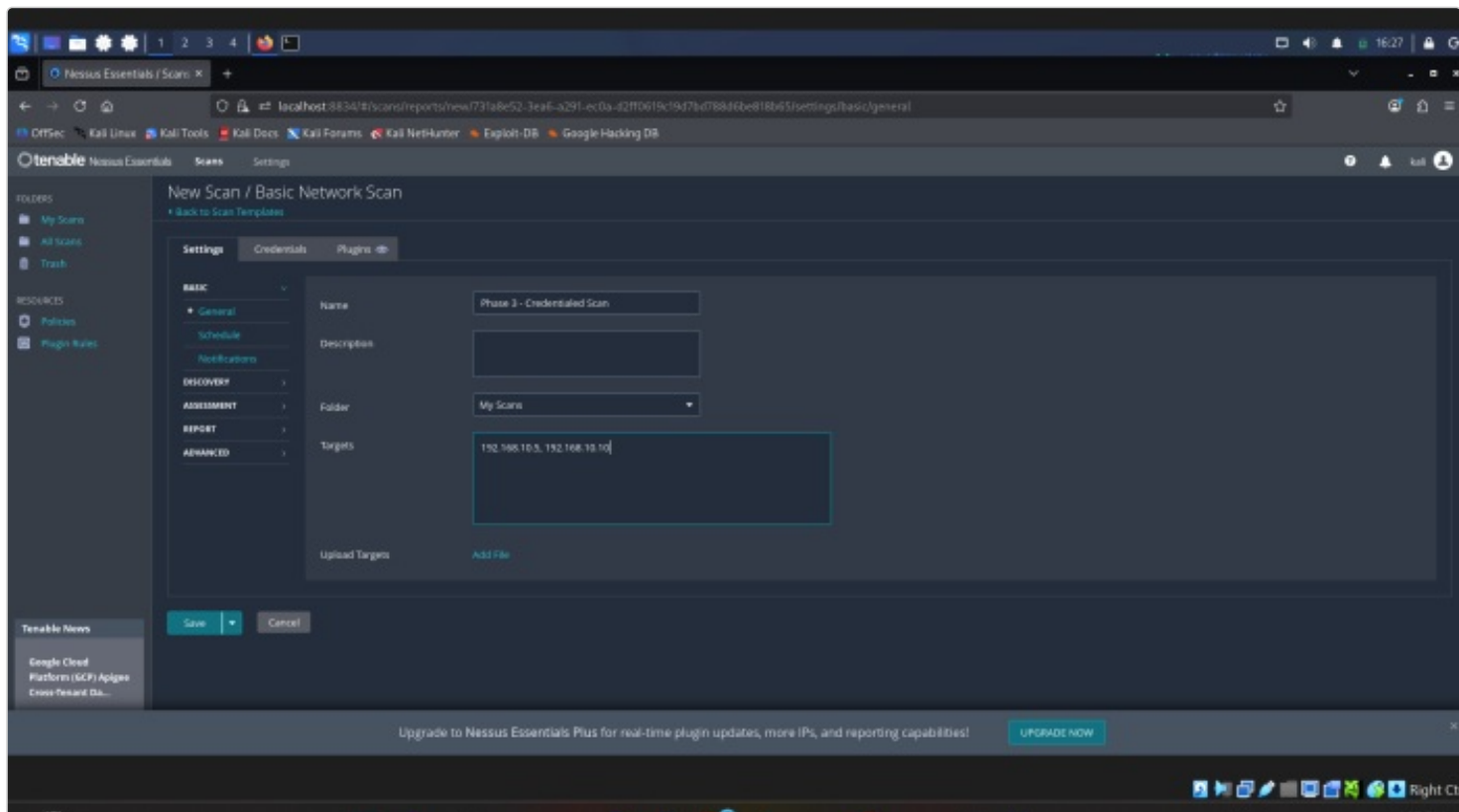
21 Enabled File and Printer Sharing through Windows Defender Firewall on the Domain profile — required for Nessus to reach Windows 11 over the network.



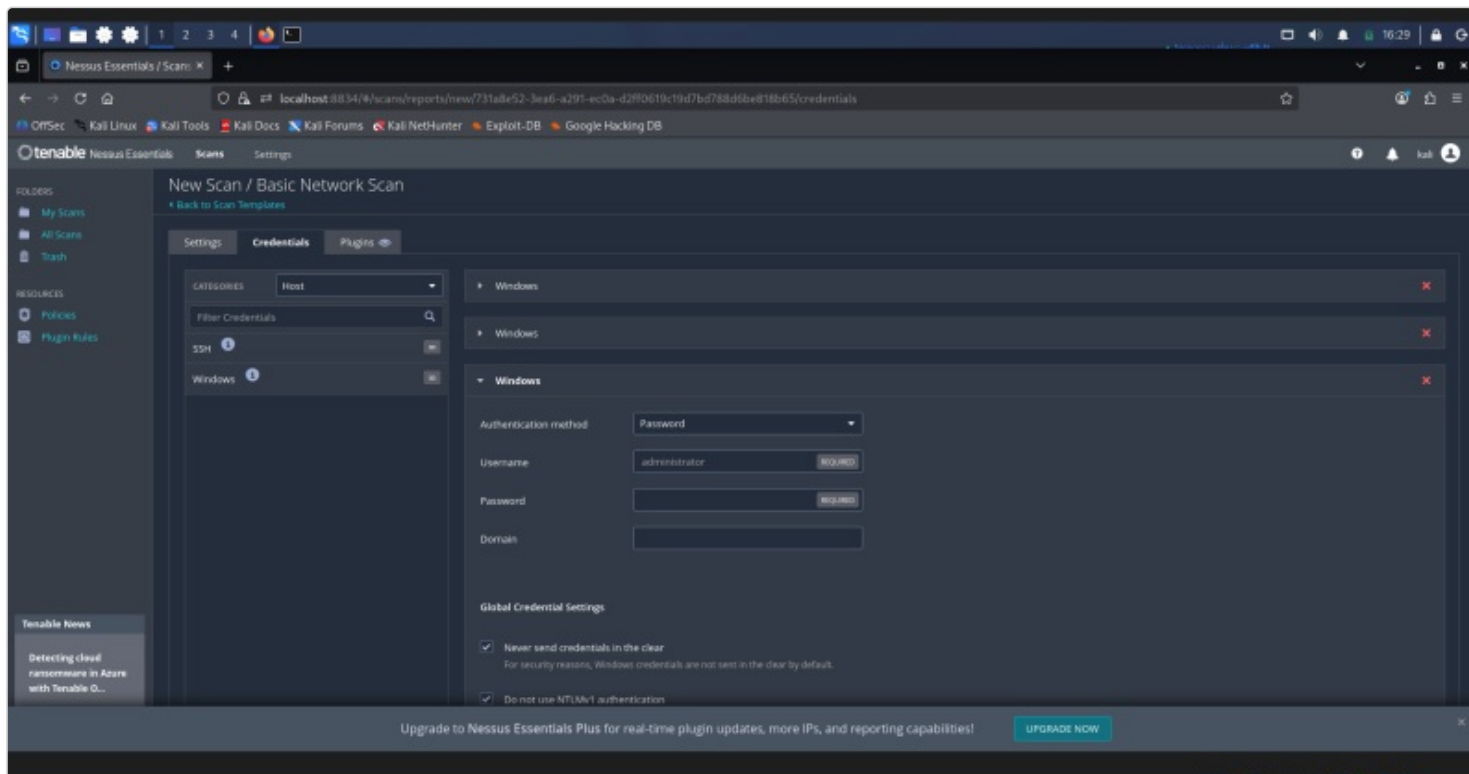
- 22 Checked the same File and Printer Sharing firewall rule on Server 2022 — Server OS usually has this enabled by default, and it was here too.



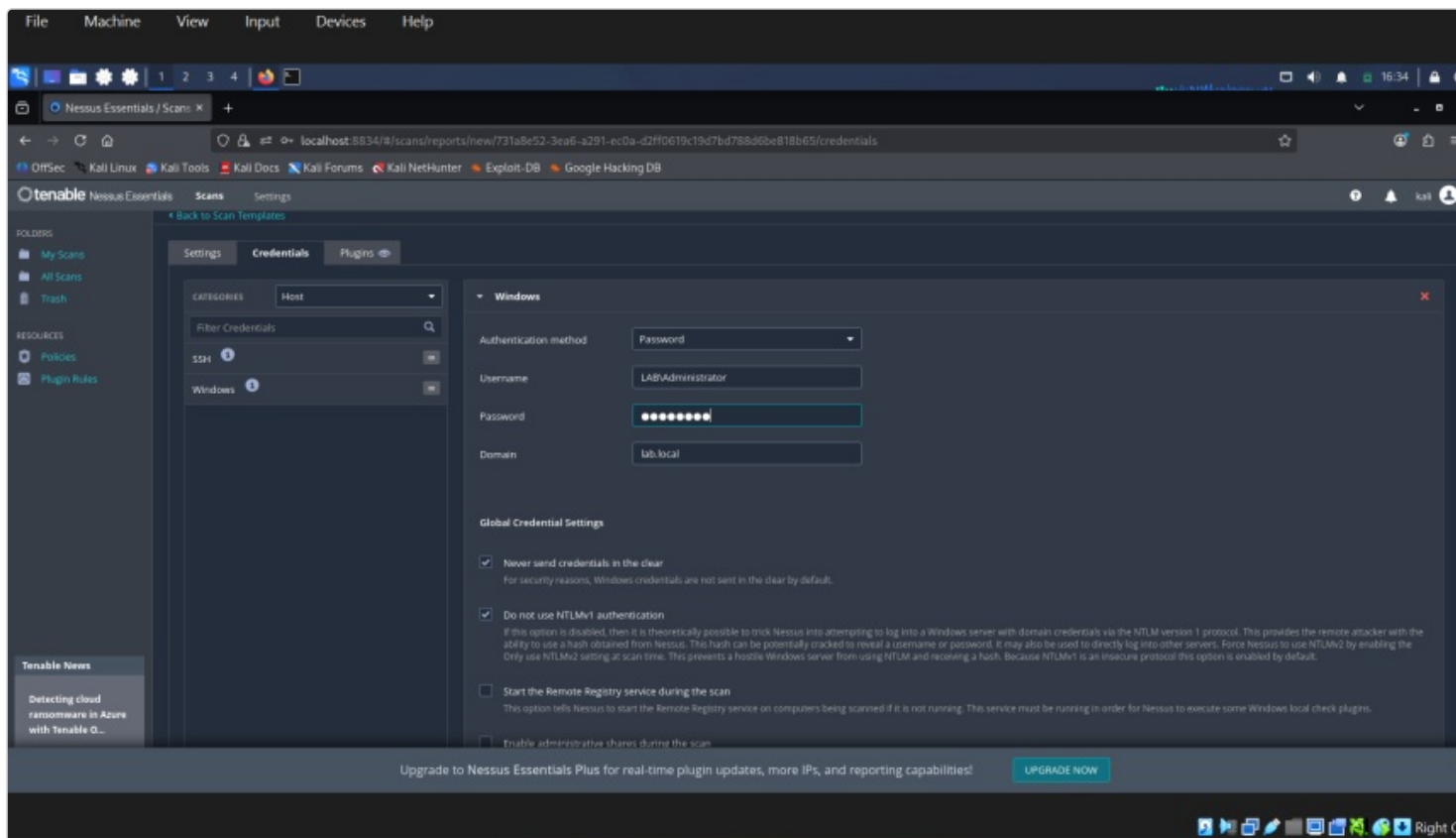
- 23 Starting a new Basic Network Scan specifically for the credentialed scan phase.



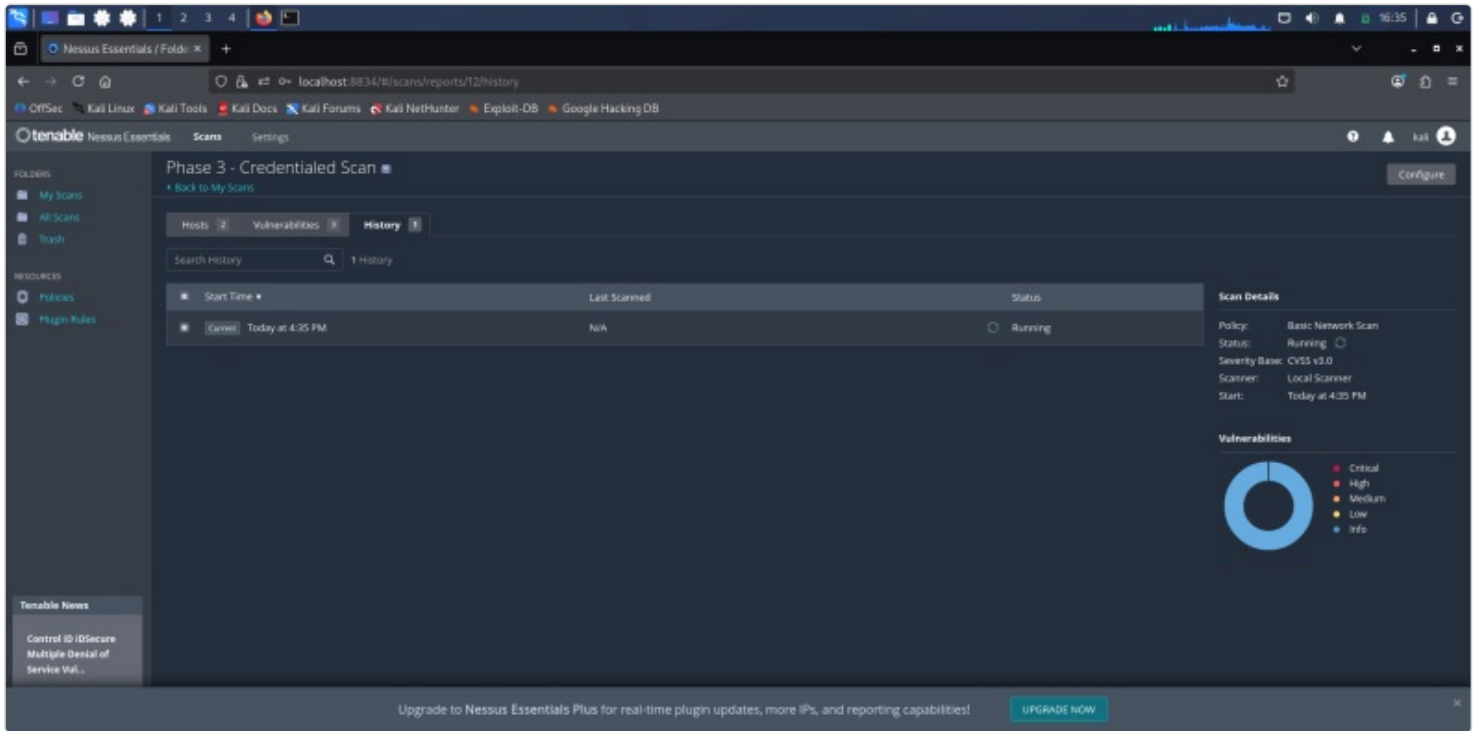
24 Opened the Windows credentials form in Nessus, where the login details for the scan get entered.



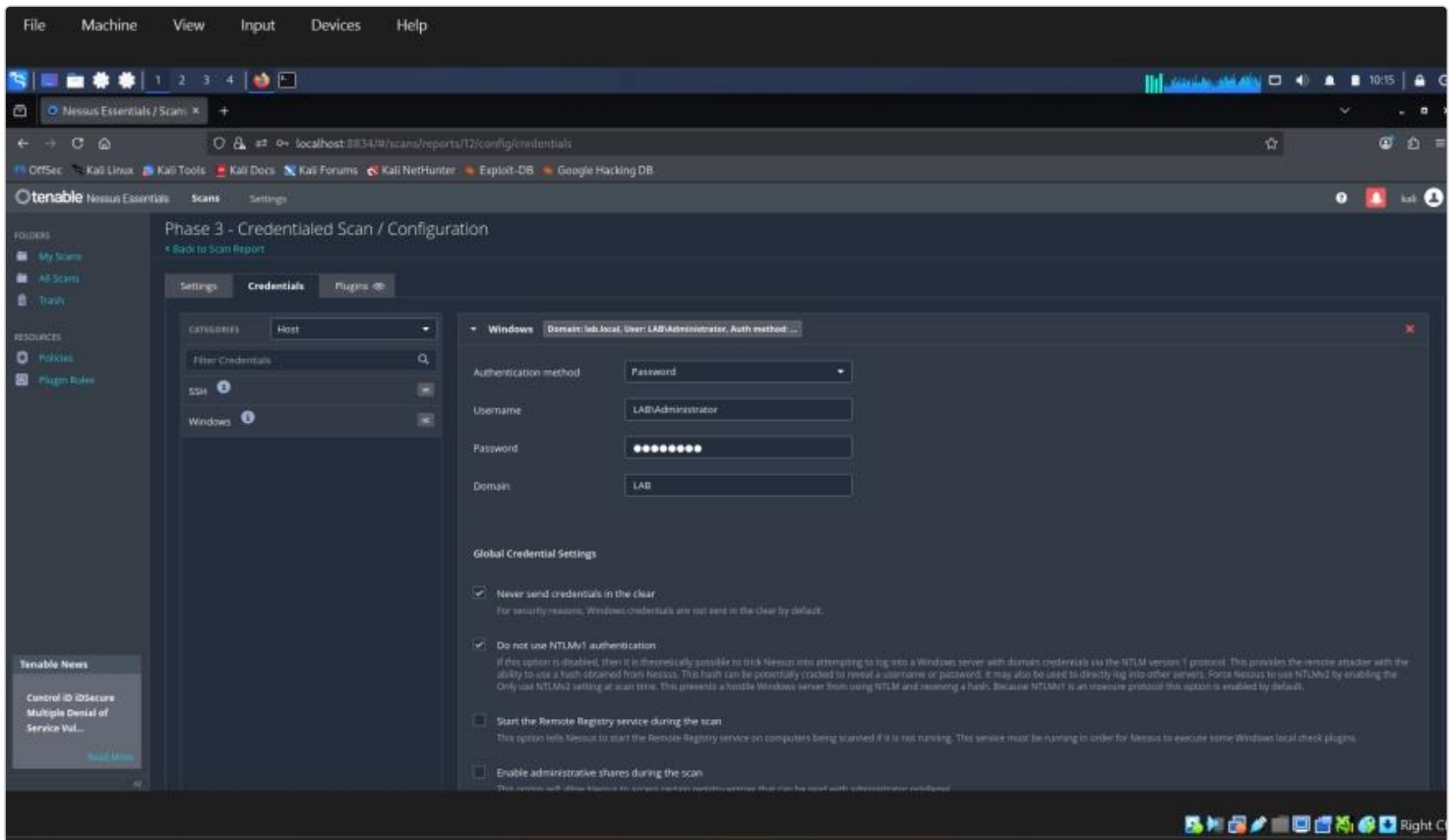
25 Entered domain Administrator credentials for the credentialed scan.



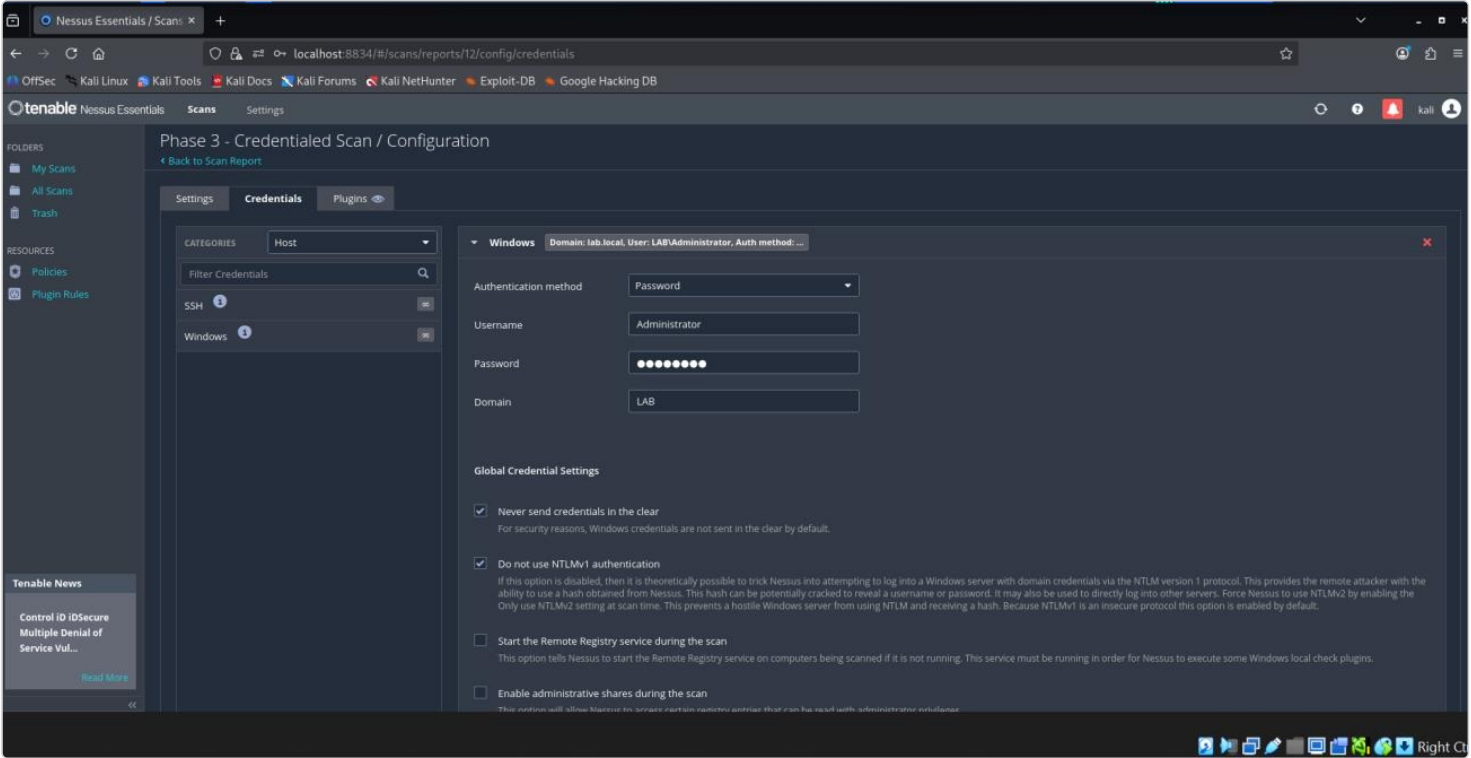
26 Launched the credentialed scan targeting Server 2022 and Windows 11.



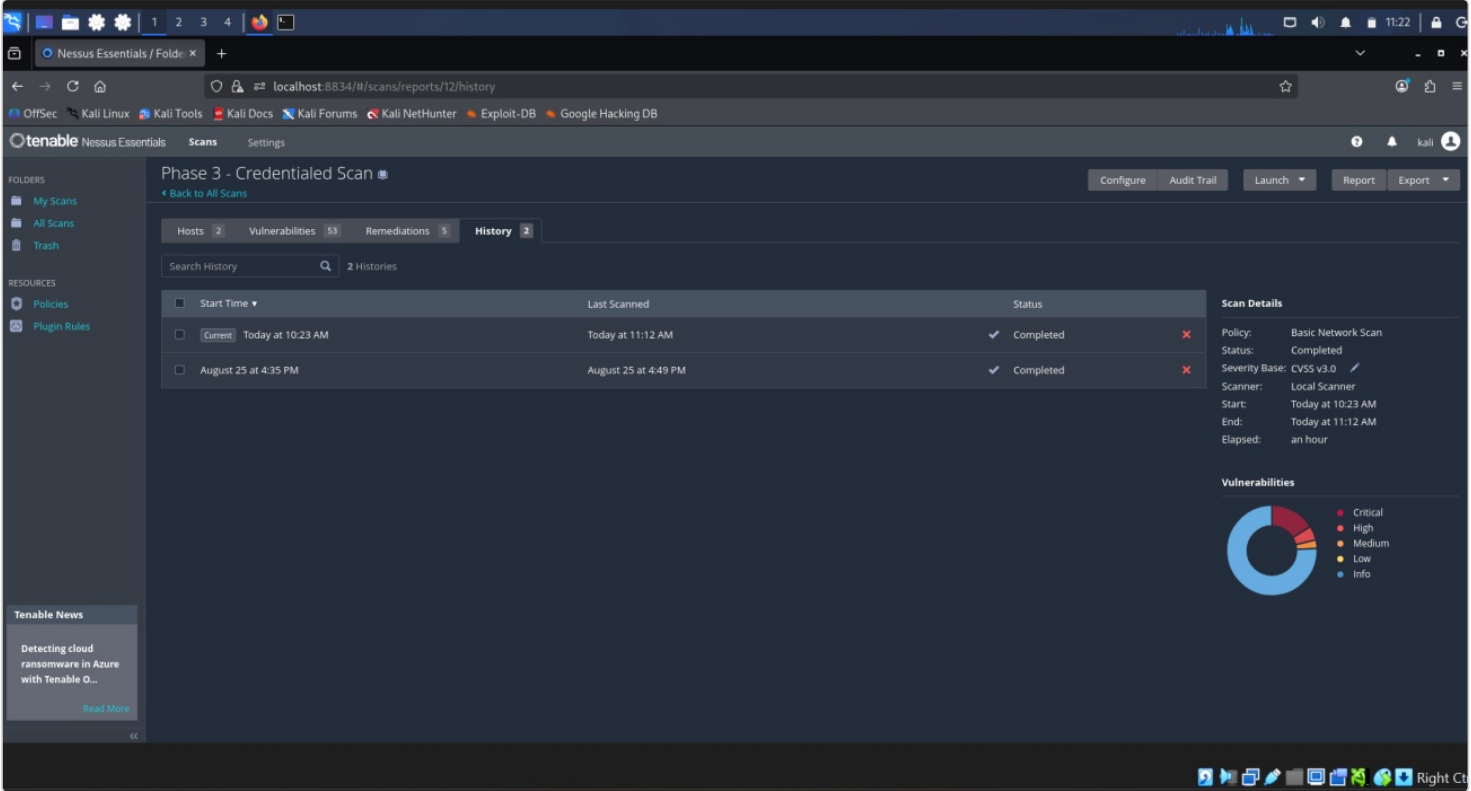
27 First result: authentication failed. Fix #1 — changed the Domain field from the full FQDN (lab.local) to the short NetBIOS name (LAB). This is a very common cause of Nessus Windows auth failures.



28 Fix #2 — removed a duplicate domain prefix from the Username field (it should just be the username, e.g. "Administrator" — not "LAB\Administrator" — since the domain is already set separately).



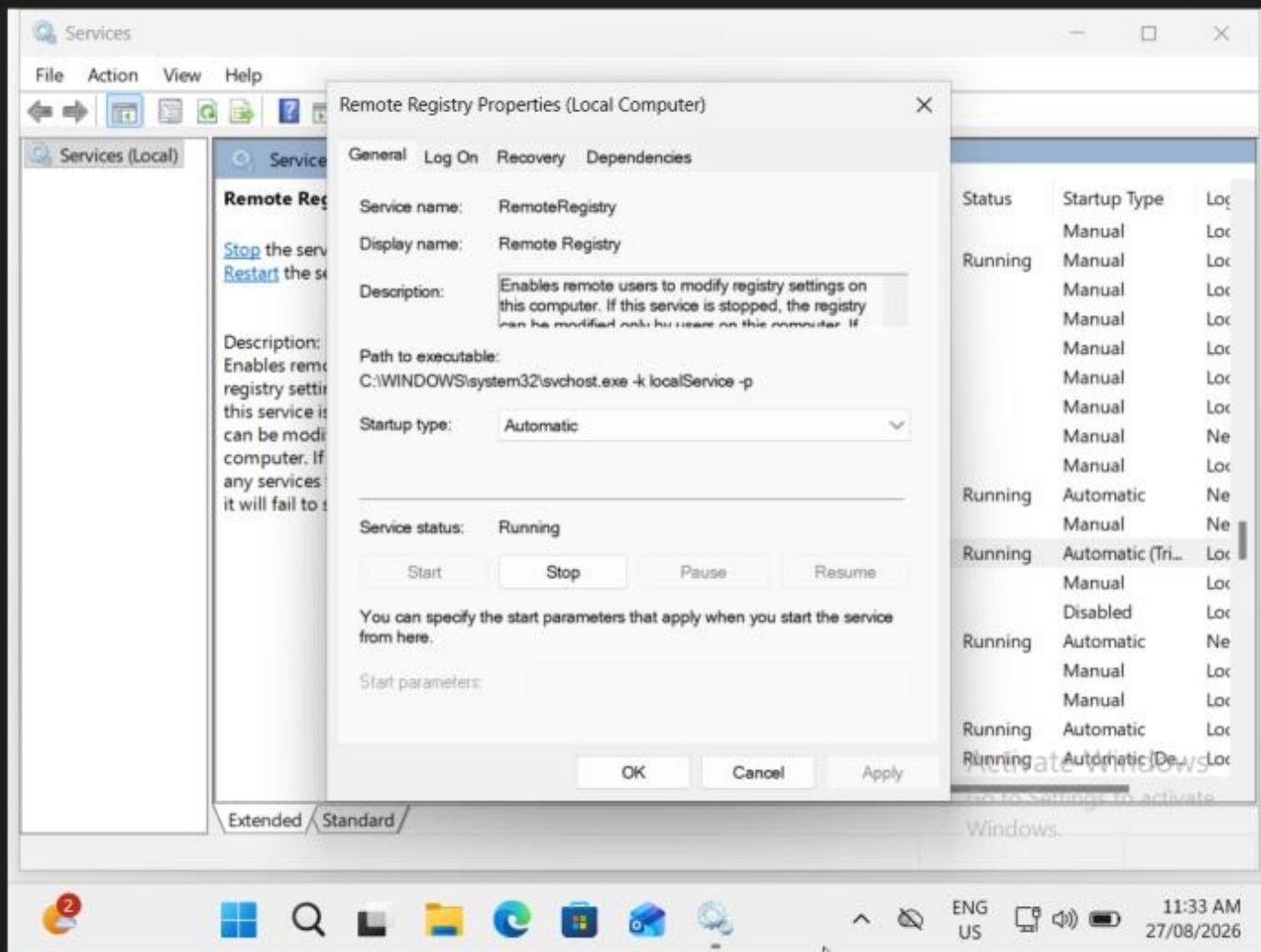
29 Reran the credentialed scan after fixing the Domain/Username fields, to check whether Auth now showed Pass.



✦ Fix #3 — Remote Registry stopped again

Remote Registry can silently stop after a reboot or idle period, even if it was enabled earlier. It had to be manually restarted on Windows 11 before the scan would authenticate.

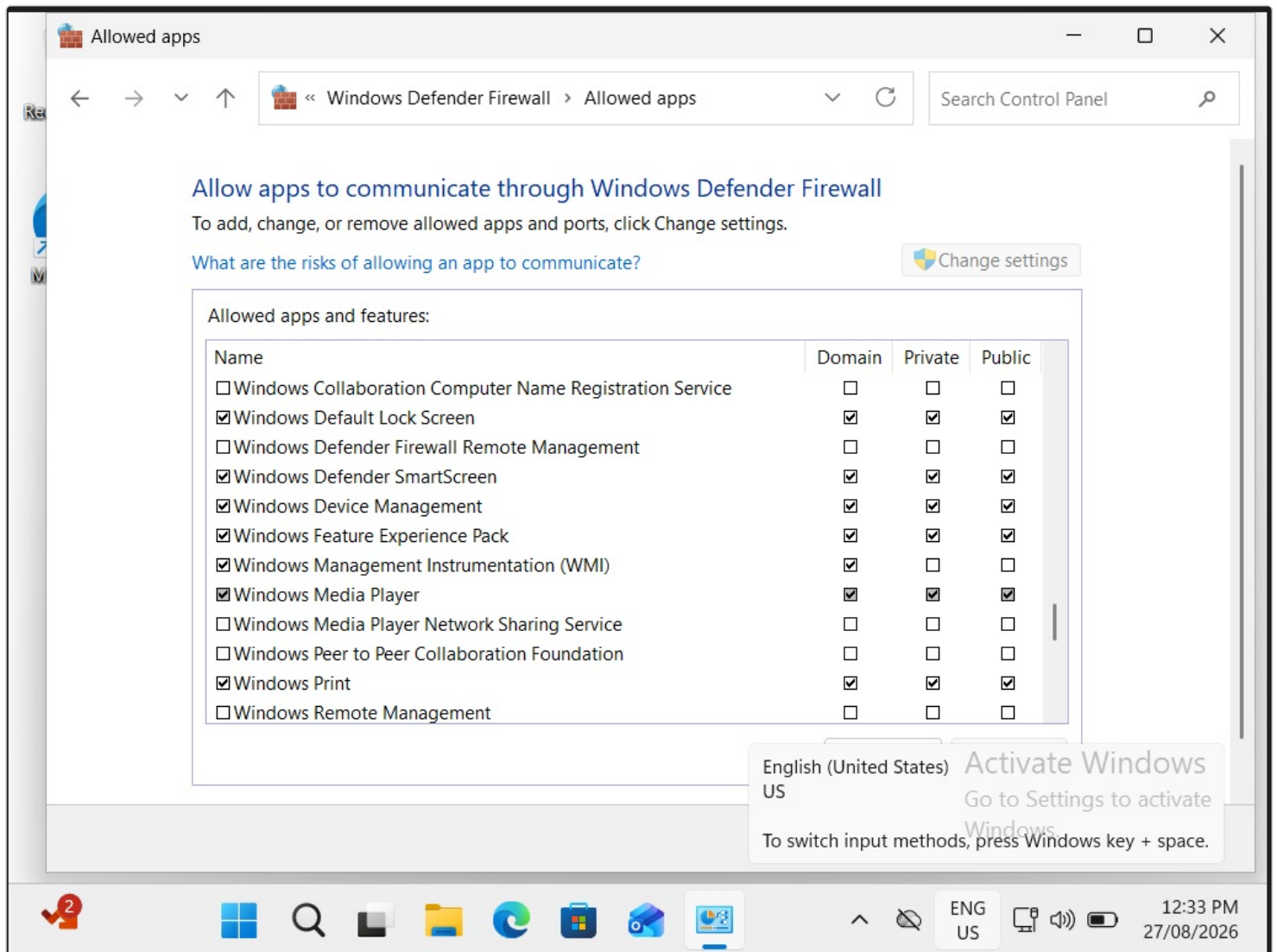
30 Fix #4 — enabled the Windows Management Instrumentation (WMI) firewall rule on the Domain profile. This is a completely separate rule from File and Printer Sharing, and it's easy to miss since both live in the same settings page.



✦ One more snag: scanning both hosts at once

With all four fixes in place, both hosts could authenticate — but scanning them **at the same time** on constrained lab hardware caused Auth to flip-flop unpredictably between hosts. Splitting the job into two separate scans, one per host, and running them one at a time, fixed it. Lesson: on a resource-limited lab, credentialed scans are more reliable run sequentially.

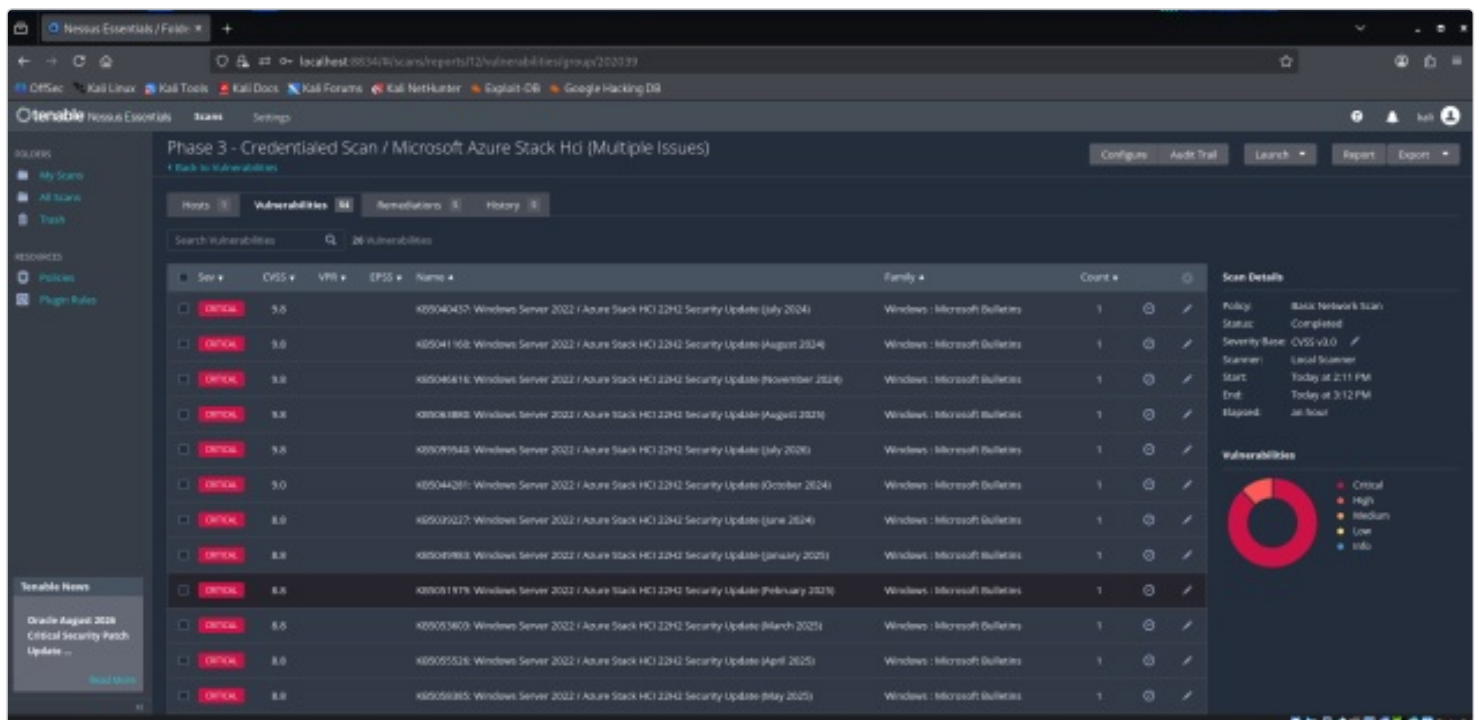
- 31 With everything fixed, sorted the Server 2022 findings by severity to begin triage — 48 Critical and 16 High severity findings on the domain controller alone, compared to just 1 notable finding from the earlier unauthenticated baseline.



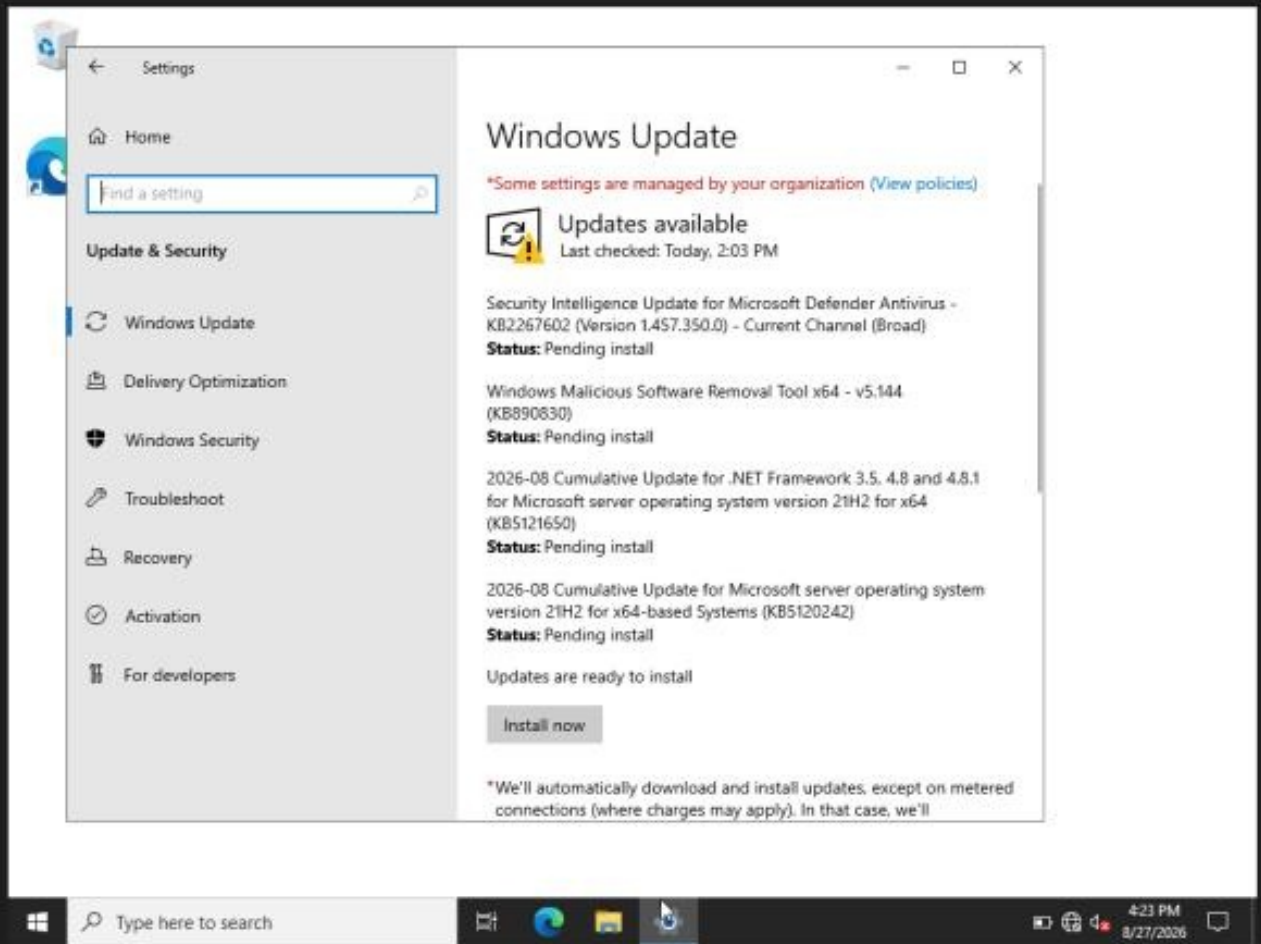
Phase 4 · Triage & Remediation

Rather than trying to fix all 50+ findings, a representative set was selected for real risk-based decision-making — documented in the Risk Register on the last page.

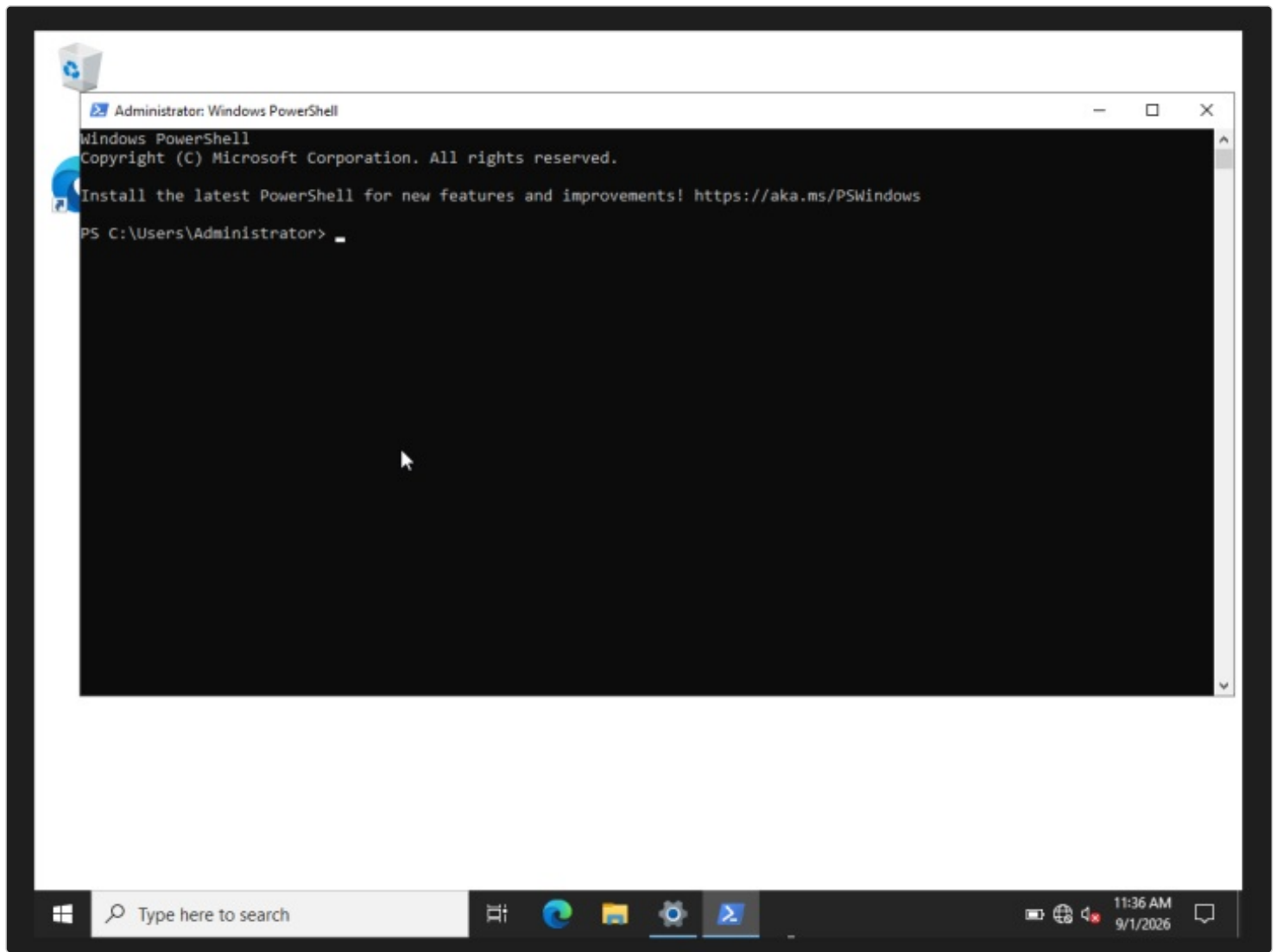
- 32 Installing the missing Windows Server 2022 and .NET Framework security updates identified by Nessus, via Windows Update.



33 Windows Update hit a real servicing error (0x800f080a) partway through. Opened an administrator PowerShell terminal to repair the underlying update components.



34 Ran `DISM /Online /Cleanup-Image /RestoreHealth` to repair the corrupted servicing components. This completed successfully and resolved the servicing error.



★ **What is DISM, and why did this matter?**

DISM (Deployment Image Servicing and Management) is a built-in Windows tool that can repair a corrupted Windows image or update system when Windows Update itself is broken. Diagnosing this error and fixing it with DISM was a real, transferable troubleshooting skill — separate from the vulnerability scanning itself, but exactly the kind of thing that comes up on the job.

Final patch installation was still finishing on constrained lab hardware (1 CPU allocated) at the time of writing. The Risk Register on the next page reflects this honestly as "**In Progress**" rather than marking the items closed prematurely.

Findings selected during triage, documented with severity, CVSS score, affected host, remediation decision, and reasoning.

Nessus Vulnerability Risk Register

Home Lab Environment — Windows Server 2022 & Windows 11

Prepared by Anush | Source: Nessus Essentials credentialed scans

ID	Finding	Host	Severity	CVSS	Decision	Reasoning
1	Missing Windows Server 2022 Security Update (KB5099540 — July 2026)	192.168.10.10 — Server 2022	Critical	9.8	Remediate	Missing cumulative OS security patch. Fix: install via Windows Update, then rescan to confirm resolution.
2	Missing .NET Framework Security Update (January 2024)	192.168.10.10 — Server 2022	Critical	9.8	Remediate	Outdated .NET Framework component with known critical CVEs. Fix: install via Windows Update, then rescan to confirm resolution.
3	SSL Certificate Cannot Be Trusted (Plugin #51192)	192.168.10.3 — Kali (Nessus mgmt, port 8834)	Medium	6.5	Accept Risk	Self-signed certificate on Nessus's own local management interface, not an externally exposed service. Low real-world risk in this lab context.

Summary

Total Findings Tracked	Findings to Remediate	Findings — Accepted Risk
3	2	1

Personal home-lab project — not professional/client work. Built while studying toward CompTIA Security+.